

Design and Coding Standards

For Documents, Computer systems and the Languages; C, Python and LaTeX

H. Bowman

Version 4.23

First revision: 2024-04-03

Latest revision: 2026-10-01

Contents

I	General Project Rules	9
I.1	Introduction	9
I.2	Scope	9
I.3	Terminology	10
I.4	General Design Principles	10
I.4.1	Correctness	11
I.4.2	Clarity	11
I.4.3	Consistency	11
I.4.4	Maintainability	11
I.4.5	Testability	11
I.4.6	Security	11
I.4.7	Portability and Reproducibility	11
I.4.8	Traceability	11
I.4.9	Automation	11
I.4.10	Small and Reviewable Changes	12
I.4.11	Documentation as a Project Artifact	12
I.5	Requirements and Rule Priority	12
I.5.1	Requirement Characteristics	12
I.5.2	Rule Priority	12
I.5.3	Mandatory and Advisory Rules	13
I.5.4	Exceptions	13
I.5.5	Compliance	13
II	Document Standards	14
II.1	Purpose	14
II.2	Scope	14
II.3	Standards	15

II.3.1	Typography and layout	15
II.3.2	Page and print standards	15
II.3.3	Writing conventions	16
II.3.4	Warnings, hazards, and precautions	16
II.3.5	Job safety analysis and task risk assessments	17
II.3.6	Risk assessment matrix	17
II.3.6.1	Likelihood scale	18
II.3.6.2	Consequence scale	18
II.3.6.3	The Matrix	18
II.3.7	Take 5 assessments	19
II.3.8	Tables, figures, and equations	19
II.3.9	Forms, records, and examples	19
II.3.10	Accessibility and digital use	20
II.3.11	Document control	20

III Computer Standards 22

III.1 Scope and Responsibilities 22

III.1.1	Purpose	22
III.1.2	Scope	22
III.1.3	Management Responsibilities	22
III.1.4	System and Service Owners	23
III.1.5	System Administrators	23
III.1.6	Users	24
III.1.7	Information and Data Owners	24
III.1.8	Security and Privacy Responsibilities	25
III.1.9	Third-Party Responsibilities	25
III.1.10	Responsibility Assignment	25
III.1.11	Review and Enforcement	26

III.2 Data classification and encryption 26

III.2.1	Purpose	26
III.2.2	Scope	26
III.2.3	Information Classification	26
III.2.4	Handling Requirements	27
III.2.5	Access Control	27
III.2.6	Encryption	28
III.2.7	Transmission and Sharing	28
III.2.8	Backup and Recovery	28
III.2.9	Disposal	29
III.2.10	Incident Reporting	29
III.2.11	Review	29

III.3 Asset inventory 29

III.4 Software inventory 31

III.5 Secure configuration 34

III.5.1	Purpose	34
III.5.2	Configuration Standards	34
III.5.3	Baseline Configurations	35
III.5.4	Configuration Management	35
III.5.5	Security Hardening	36
III.5.6	Configuration Review	36
III.5.7	Configuration Exceptions	37
III.5.8	Responsibility	37

III.6	Patch and vulnerability management	37
III.6.1	Purpose	37
III.6.2	Asset Coverage	37
III.6.3	Vulnerability Identification	38
III.6.4	Vulnerability Assessment	38
III.6.5	Patch Priorities	39
III.6.6	Patch Testing	39
III.6.7	Patch Deployment	39
III.6.8	Emergency Remediation	40
III.6.9	Verification and Reporting	40
III.6.10	Exceptions and Compensating Controls	40
III.7	Account and access management	41
III.7.1	Purpose	41
III.7.2	Account Requirements	41
III.7.3	Access Requests and Approval	41
III.7.4	Privileged Access	42
III.7.5	Authentication	42
III.7.6	Account Provisioning	42
III.7.7	Changes to Access	43
III.7.8	Account Termination	43
III.7.9	Access Reviews	44
III.7.10	Inactive and Dormant Accounts	44
III.7.11	Emergency and Break-Glass Accounts	44
III.7.12	Third-Party Access	45
III.7.13	Account and Access Records	45
III.8	Password Management	45
III.8.1	Password Hashing and Encryption	45
III.8.2	Access Control and Accountability	46
III.8.3	Credential Lifecycle	46
III.8.4	Password and Secret Recovery	46
III.8.5	Physical Password Storage	47
III.8.5.1	Split custody	47
III.9	Malware and endpoint protection	48
III.9.1	Purpose	48
III.9.2	Endpoint Inventory	48
III.9.3	Endpoint Security Controls	48
III.9.4	Secure Endpoint Configuration	49
III.9.5	Malware Protection	49
III.9.6	Software and Application Control	50
III.9.7	Removable Media	50
III.9.8	Email, Web, and File Protection	50
III.9.9	Endpoint Isolation and Response	51
III.9.10	Mobile and Remote Endpoints	51
III.9.11	Endpoint Review	51
III.10	Logging and monitoring	52
III.10.1	Purpose	52
III.10.2	Logging Requirements	52
III.10.3	Log Content	53
III.10.4	Centralized Log Collection	53
III.10.5	Log Protection and Access	54
III.10.6	Log Retention	54
III.10.7	Monitoring and Alerting	54

III.10.8	Review and Investigation	55
III.10.9	Monitoring Privacy and Data Minimization	55
III.10.10	Availability of Logging Systems	56
III.10.11	Review of Logging and Monitoring Controls	56
III.11	Backups and restoration	56
III.11.1	Purpose	56
III.11.2	Backup Scope	57
III.11.3	Backup Security	57
III.11.4	Offline and Immutable Copies	58
III.11.5	Backup Scheduling and Retention	58
III.11.6	Backup Monitoring	58
III.11.7	Restore Testing	59
III.11.8	Recovery Procedures	59
III.12	Network management	59
III.12.1	Purpose	59
III.12.2	Network Inventory and Ownership	60
III.12.3	Network Architecture and Segmentation	60
III.12.4	Firewalls and Access Controls	61
III.12.5	Wireless Networks	61
III.12.6	Remote Access and VPN	62
III.12.7	Network Device Configuration	62
III.12.8	Network Changes	63
III.12.9	Network Availability and Capacity	63
III.12.10	Network Security Monitoring	63
III.12.11	Network Review	64
III.13	Change management	64
III.13.1	Purpose	64
III.13.2	Change Requirements	65
III.13.3	Change Classification	65
III.13.4	Change Requests	65
III.13.5	Change Assessment	66
III.13.6	Testing	66
III.13.7	Implementation	67
III.13.8	Rollback and Recovery	67
III.13.9	Post-Implementation Review	67
III.13.10	Emergency Changes	68
III.13.11	Separation of Duties	68
III.13.12	Change Records	68
III.13.13	Unauthorized Changes	69
III.14	Incident response	69
III.14.1	Purpose	69
III.14.2	Incident Definition	69
III.14.3	Incident Response Responsibilities	70
III.14.4	Incident Reporting	70
III.14.5	Incident Classification	71
III.14.6	Incident Response Process	71
III.14.7	Containment	72
III.14.8	Evidence Preservation and Investigation	72
III.14.9	Eradication and Recovery	73
III.14.10	Communication and Notification	73
III.14.11	Post-Incident Review	73
III.14.12	Incident Records	74

III.14.13	Testing and Maintenance	74
III.15	Physical security	75
III.15.1	Purpose	75
III.15.2	Scope	75
III.15.3	Physical Access	75
III.15.4	Visitors and Contractors	75
III.15.5	Restricted Areas	76
III.15.6	Equipment Protection	76
III.15.7	Clear Desk and Clear Screen	76
III.15.8	Environmental Protection	76
III.15.9	Removable Media	77
III.15.10	Remote and Home Work Areas	77
III.15.11	Equipment Removal and Disposal	77
III.15.12	Physical Security Incidents	78
III.15.13	Review	78
III.16	System decommissioning	78
III.16.1	Purpose	78
III.16.2	Scope	78
III.16.3	Decommissioning Authorization	78
III.16.4	Dependency Review	79
III.16.5	Data Retention and Transfer	79
III.16.6	Account and Credential Removal	80
III.16.7	Data Sanitization	80
III.16.8	Hardware and Media Disposal	80
III.16.9	Service and Cloud Decommissioning	81
III.16.10	Verification	81
III.16.11	Emergency Decommissioning	82
III.16.12	Records	82
III.16.13	Review	82
III.17	Review, testing, and exceptions	82
III.17.1	Purpose	82
III.17.2	Scope	82
III.17.3	Periodic Review	83
III.17.4	Control Testing	83
III.17.5	Test Planning	83
III.17.6	Results and Corrective Actions	84
III.17.7	Exception Requirements	84
III.17.8	Exception Approval	85
III.17.9	Compensating Controls	85
III.17.10	Exception Review and Closure	85
III.17.11	Evidence and Records	86
III.17.12	Reporting	86
III.17.13	Continuous Improvement	86
IV	C Programming Standard	87
IV.1	General Principles	87
IV.2	C11 Language Subset	88
IV.2.1	Permitted Language	88
IV.2.2	Prohibited or Restricted Features	88
IV.3	Formatting	89

IV.3.1	Indentation	89
IV.3.2	Alignment	89
IV.3.3	Braces	89
IV.3.4	Whitespace	89
IV.3.5	Line Length	90
IV.3.6	Automated Formatting	90
IV.4	Naming	90
IV.4.1	General Naming Requirements	90
IV.4.2	Functions	90
IV.4.3	Variables	91
IV.4.4	Types	91
IV.4.5	Constants and Macros	91
IV.4.6	Private Names	91
IV.5	Variables	91
IV.5.1	General Variable Requirements	91
IV.6	Module Boundaries	91
IV.6.1	Module Structure	91
IV.6.2	Header Independence	92
IV.6.3	Include Ownership	92
IV.6.4	Circular Dependencies	92
IV.7	Visibility	92
IV.7.1	Public Declarations	92
IV.7.2	Private Declarations	93
IV.7.3	Global Variables	93
IV.7.4	Opaque Types	93
IV.8	Type Safety	93
IV.8.1	Fixed-Width Integer Types	93
IV.8.2	Boolean Values	94
IV.8.3	Enumerations	94
IV.8.4	Explicit Conversions	94
IV.8.5	Const Correctness	94
IV.8.6	Additional Rules	94
IV.9	Initialization	95
IV.9.1	General Requirement	95
IV.9.2	Default Initialization	95
IV.9.3	Structures	95
IV.9.4	Arrays	95
IV.9.5	Pointers	95
IV.9.6	Static Storage	95
IV.9.7	Initialization Functions	96
IV.9.8	Partial Initialization	96
IV.10	Control Flow	96
IV.10.1	Control Flow	96
IV.10.2	Loops	96
IV.11	Functions	96
IV.11.1	Function Requirements	96
IV.11.2	Parameter Validation	97
IV.11.3	Return Values	97

IV.12 Memory Safety	97
IV.12.1 General Requirement	97
IV.12.2 Allocation Policy	98
IV.12.3 Allocation Arithmetic	98
IV.12.4 Ownership	99
IV.13 Arrays and Strings	99
IV.13.1 Array Bounds	99
IV.13.2 String Handling	99
IV.13.3 Binary Data	99
IV.14 Pointers	99
IV.15 Integer Safety	99
IV.16 Error Handling	99
IV.17 Preprocessor	99
IV.18 External Libraries	99
IV.18.1 Library Policy	99
IV.18.2 Approval Requirements	100
IV.18.3 Wrapper Requirement	100
IV.19 Concurrency	100
IV.19.1 Applicability	100
IV.19.2 Shared State	100
IV.19.3 Ownership	101
IV.19.4 Mutexes	101
IV.19.5 Lock Ordering	101
IV.19.6 Atomics	101
IV.19.7 Interrupts and Signal Handlers	101
IV.19.8 Thread Cancellation	101
IV.19.9 Testing	102
IV.20 Documentation	102
IV.20.1 Documentation Requirements	102
IV.20.2 Public Interfaces	102
IV.20.3 Module Documentation	103
IV.20.4 Comments	103
IV.20.5 TODO Comments	103
IV.20.6 Generated Documentation	103
IV.21 Tooling	103
IV.21.1 Compiler	103
IV.21.2 Analysis	104
IV.21.3 Required Build Checks	104
IV.22 Exceptions	104
IV.22.1 Purpose	104
IV.22.2 When an Exception Is Required	104
IV.22.3 Exception Record	105
IV.22.4 Warning Suppression	105
IV.22.5 Review	106

V	Python Programming Standard	107
V.1	Python Formatting	107
V.1.1	Formatting Rules	107
V.1.2	Code Organization	107
V.2	Python Documentaion	107
V.2.1	General Documentaion Rules	107
V.3	Python Naming	107
V.4	Python Imports	107
V.4.1	Import Rules	107
V.5	Type Hints	108
V.5.1	Type Hints	108
V.6	Functions and Classes	108
V.7	Error Handling	108
V.7.1	General Error Handling	108
V.8	Testing	108
V.8.1	General Testing	108
V.9	Python Review Checklist	108
VI	Tooling and Verification	109
VII	Development Process	109
A	Example Documents:	110
VII.1.0.1	A clean JSA	110
VII.1.0.2	A clean Take 5	116
B	C Review Checklist	119
C	Python Review Checklist	119
D	Release Checklist	119
	References	119

Part I

General Project Rules

I.1 Introduction

This document defines the general standards, rules, and working practices used by the author. Its purpose is to establish a consistent approach to software development, computing environments, documentation, testing, review, and maintenance.

The standards in this document are intended to improve the quality, readability, maintainability, portability, security, and reliability of projects. They apply to source code, configuration files, development tools, computer systems, technical documentation, and project processes.

The document is divided into several areas. The general project rules define principles that apply to the entire project. The document standards define requirements for written and technical documentation. The computer standards define requirements for development and execution environments. Language specific sections define rules for programming languages such as C and Python. Additional sections describe tooling, verification, code review, testing, and the process for requesting exceptions to these standards.

These standards should be used during planning, implementation, review, testing, release, and maintenance. They are intended to support developers rather than replace engineering judgment. Where a specific project requirement conflicts with a general recommendation, the applicable priority rules in this document shall be used.

I.2 Scope

These standards apply to all projects activities, including:

- source code and scripts;
- build systems and build configurations;
- test code, test data, and verification procedures;
- configuration files and deployment files;
- development, build, test, and execution environments;
- technical, user, operational, and project documentation;
- continuous integration and other automated tooling;
- code reviews and change reviews;
- release packages and maintenance activities.

The standards apply to all contributors, including permanent developers, temporary contributors, reviewers, maintainers, and other individuals who create or modify project deliverables.

Unless a section explicitly states otherwise, a requirement applies to both new work and modifications to existing work. Existing code or documentation does not need to be changed solely to satisfy a newly introduced standard unless it is being substantially modified, reviewed for compliance, or identified as a risk.

This document does not replace external legal, regulatory, contractual, safety, security, or organizational requirements. Where such requirements apply, they shall be identified and incorporated into the relevant project plans and deliverables.

The scope of a particular rule may be limited by the rule itself. For example, a rule may apply only to C source code, Python source code, user-facing documentation, or systems used to build and test the project.

I.3 Terminology

Unless otherwise specified, the following terms are used throughout this document.

MUST Indicates a mandatory requirement. A deviation requires an approved exception.

MUST NOT Indicates a mandatory prohibition. The described action or condition is not permitted unless an approved exception explicitly allows it.

SHOULD Indicates a strong recommendation. A deviation is permitted when there is a documented technical reason.

SHOULD NOT Indicates a strong recommendation to avoid an action or condition. A deviation should have a documented technical reason.

MAY Indicates permission or an optional practice. It does not impose a requirement.

DO NOT Indicates a direct instruction to avoid an action. It is normally used for procedural instructions and prohibitions.

Project Refers to the software, documentation, tools, configuration, infrastructure, and processes governed by this document.

Source Code Human-readable code written in a programming language, including production code, test code, scripts, and supporting utilities.

Build The process of transforming source code, configuration, and other inputs into executable programs, libraries, packages, or other generated artifacts.

Development Environment The hardware, operating system, software, tools, libraries, settings, and services used to develop or maintain the project.

Verification The activities used to determine whether a deliverable satisfies specified requirements. Examples include reviews, static analysis, automated tests, and manual checks.

Validation The activities used to determine whether the completed system meets its intended purpose and user or stakeholder needs.

Review A structured examination of a deliverable or change by one or more people other than its author.

Change Any addition, deletion, or modification to project code, documentation, configuration, tooling, or process.

Release A formally identified version of the project made available for use, distribution, deployment, or further integration.

Exception An approved deviation from a mandatory requirement in this document.

Configuration Item A project artifact placed under version control or otherwise managed as part of the project's controlled baseline.

The words "**MUST**", "**SHOULD**", and "**MAY**" are interpreted according to the definitions above. These terms are intentionally used consistently so that the strength of each rule is clear.

I.4 General Design Principles

The project shall be developed and maintained according to the following general principles.

I.4.1 Correctness

Implementation decisions shall prioritize satisfying the documented requirements and preserving correct behavior. Code and documentation shall not rely on assumptions that are inconsistent with the project requirements.

I.4.2 Clarity

Code, configuration, and documentation shall be written so that they can be understood by an appropriately skilled contributor who was not the original author. Clear names, simple structures, consistent formatting, and concise documentation should be preferred over clever or unnecessarily complex solutions.

I.4.3 Consistency

Similar problems shall be solved in similar ways unless a documented reason justifies a different approach. Project conventions shall be applied consistently across source code, documentation, directory structures, configuration, and tooling.

I.4.4 Maintainability

Designs should minimize unnecessary coupling and complexity. Components should have clear responsibilities, stable interfaces, and appropriate separation of concerns. Changes should be made in a way that reduces the long-term cost of maintenance.

I.4.5 Testability

Important behavior shall be designed so that it can be verified. New or modified functionality should include appropriate tests, checks, or other evidence that the implementation satisfies its requirements.

I.4.6 Security

Security-relevant requirements shall be considered throughout the development lifecycle. Sensitive data shall be protected, access shall be limited to what is necessary, and unsafe defaults shall be avoided.

I.4.7 Portability and Reproducibility

The project should avoid unnecessary dependence on a particular computer, operating system, compiler, interpreter, tool version, or local configuration. Builds, tests, and other important activities should be reproducible using documented dependencies and procedures.

I.4.8 Traceability

Requirements, implementation decisions, tests, defects, reviews, and releases should be traceable where practical. The level of traceability shall be appropriate to the size, risk, and purpose of the project.

I.4.9 Automation

Repetitive checks should be automated where practical. Formatting checks, static analysis, tests, documentation generation, and other suitable verification activities should be integrated into the normal development workflow.

I.4.10 Small and Reviewable Changes

Changes should be limited to a clear purpose and kept small enough to review effectively. Unrelated refactoring, formatting changes, or file movements should not be combined with functional changes unless there is a clear benefit.

I.4.11 Documentation as a Project Artifact

Documentation shall be treated as part of the project rather than as an optional supplement. Documentation affected by a change shall be updated as part of that change.

I.5 Requirements and Rule Priority

This section defines how requirements and rules in this document shall be interpreted and prioritized.

I.5.1 Requirement Characteristics

Project requirements should be:

- clear and unambiguous;
- necessary for the intended purpose;
- feasible within the available resources;
- verifiable through review, testing, analysis, or inspection;
- consistent with other applicable requirements;
- traceable to an identified source or stakeholder need.

When a requirement is unclear, the ambiguity shall be resolved before the affected work is finalized. The resolution should be recorded when it may affect implementation, testing, review, or future maintenance.

I.5.2 Rule Priority

When two requirements or rules conflict, they shall normally be applied in the following order of priority:

1. applicable laws, regulations, and safety requirements;
2. contractual, customer, or externally imposed requirements;
3. approved project-specific requirements;
4. requirements in this document;
5. organizational or team conventions;
6. general recommendations and personal preferences.

A more specific rule takes precedence over a more general rule at the same priority level. A language-specific rule takes precedence over a general code rule when the two rules address the same subject.

Conflicts shall not be resolved silently. The conflict, its impact, and the chosen resolution should be documented when the decision may affect the project or future contributors.

I.5.3 Mandatory and Advisory Rules

Rules using the word “**MUST**” are mandatory. A mandatory rule shall be followed unless an approved exception has been granted.

Rules using the word “**SHOULD**” are advisory but represent the expected default practice. A deviation should have a reasonable technical justification, especially when it affects maintainability, portability, security, or verification.

Rules using the word “**MAY**” identify an allowed option and do not impose a requirement.

I.5.4 Exceptions

An exception is required when a mandatory rule cannot be followed. Exceptions shall be documented before release of the affected deliverable and should include:

- the rule being waived;
- the affected files, components, or deliverables;
- the reason for the exception;
- the risks introduced by the deviation;
- any compensating controls;
- the approving person or authority;
- an expiration date or review condition, where appropriate.

Exceptions should be limited in scope and duration. Temporary exceptions shall be reviewed periodically and removed when they are no longer required.

I.5.5 Compliance

Compliance may be demonstrated through code review, automated checks, static analysis, testing, inspection, documentation review, or other appropriate verification methods.

A violation discovered during review shall be corrected, formally accepted as an exception, or recorded as a known issue with an assigned owner and planned resolution.

Part II

Document Standards

II.1 Purpose

This document defines the minimum formatting, writing, accessibility, and document-control requirements for documentaion.

These requirements are intended to ensure that documents are:

- clear and easy to read;
- usable on screen and when printed;
- consistent across departments and procedures;
- accessible to users with different visual and reading needs;
- suitable for safe and repeatable laboratory work; and
- easy to review, approve, revise, and archive.

II.2 Scope

This standard applies to all new and substantially revised documents. This includes, but is not limited to:

- standard operating procedures;
- laboratory test and analysis methods;
- sample handling procedures;
- equipment operating instructions;
- cleaning, maintenance, and calibration procedures;
- safety and waste-disposal procedures;
- quality control and quality assurance procedures;
- work instructions and checklists; and
- forms, templates, and records associated with the documents above.

This standard applies to documents distributed electronically, printed, or both. It applies to the source files, generated PDF files, and printed copies where those formats are under the control of the document owner.

This standard covers:

- page size, margins, binding offsets, headers, footers, and page numbering;
- typography, colour, spacing, headings, lists, tables, and figures;
- the wording and presentation of warnings, cautions, and notices;
- accessibility and readability requirements;
- units, symbols, abbreviations, dates, and numerical values;
- document structure and procedure-writing conventions; and

- document identification, revision history, approval, and review.

This standard does not replace technical, legal, regulatory, safety, or quality-system requirements. Where another applicable requirement is more stringent than this standard, the more stringent requirement **MUST** be followed. Any conflict or approved exception **MUST** be documented and authorised by the responsible document owner.

Documents created before the effective date of this standard **SHOULD** be updated during their next scheduled review. They **MAY** be updated earlier when changes to the procedure, equipment, hazards, regulations, or quality system require revision.

Unless an approved exception exists, all documents within the scope of this standard **MUST** conform to the requirements marked **MUST**. Requirements marked **SHOULD** are recommended and **MAY** be omitted only where there is a documented reason. Requirements marked **MAY** are optional. Requirements marked **MUST NOT** or **SHOULD NOT** prohibit or discourage the stated practice, respectively.

II.3 Standards

II.3.1 Typography and layout

Use only sans-serif typeface throughout.

Font sizes should follow as such:

- Document title:
- Major headings (Heading 1):
- Minor Headings (Heading 2):
- Sub Headings (Heading 3):
- Body text:
- Captions, footnotes, and metadata: no smaller than 9 pt when printed

Use left-aligned text with a ragged right edge; avoid fully justified text.

Avoid relying on italics, underlining, colour, or capitalisation alone to convey meaning.

Use bold only for emphasis, labels, and headings. Not for large blocks of text.

Do not use all capital body text.

Keep headings with the following paragraph.

Avoid leaving headings alone at the bottom of a page.

Use consistent spacing before and after headings, lists, tables, and figures.

Avoid decorative elements that consume space or reduce print clarity.

II.3.2 Page and print standards

margins should follow as:

- Left: 15mm
- Right: 15mm
- Top: 15mm

- Bottom: 15mm
- Binding offset: 10 mm

Ensure the binding offset is applied to the inner edge of facing pages, not always to the left edge.

Use a page size of A4.

Use black text on a white background for normal content.

Ensure every page remains understandable when printed in grayscale.

Keep tables and figures within the printable area.

DO NOT place essential information in headers or footers.

Use page numbers in the bottom right corner, except where a document control system requires a different position.

Include the document identifier and revision number in the header or footer.

II.3.3 Writing conventions

Write using Australian english spelling.

Write using direct, imperative language: "Close the valve," not "The valve should be closed."

Use consistent terminology.

Use one action per numbered step where possible.

Number steps in the order they must be performed.

Use substeps for dependent actions, such as 1.1, 1.2, and 1.3.

State quantities, units, tolerances, temperatures, timings, and acceptance criteria explicitly.

Use SI units consistently, with a space between the number and unit: 25 °C, 10 mL, and 5 min.

Use a leading zero for values below one: 0.5 mL

Use a zero after a decimal point where appropriate: 5.0 mL

Define the required precision and rounding rules for measurements.

Use one date format throughout, preferably yyyy-mm-dd

Define abbreviations at first use and maintain an approved abbreviation list.

Use the same name for the same item throughout the document.

Avoid ambiguous terms such as "regularly", "as needed", "soon" or "a small amount" unless they are defined.

Avoid unexplained symbols and specialist abbreviations.

Specify what to do when a result is outside limits or a step cannot be completed.

State required prerequisites, training, equipment, materials, and personal protective equipment before the procedure begins.

Include a clear "stop and escalate" condition for unsafe or unexpected situations.

II.3.4 Warnings, hazards, and precautions

Warnings must appear immediately before the step or condition to which they apply.

A warning must state the hazard, consequence, and required action.

Red may be used as a secondary visual cue, but meaning must remain clear when printed in grayscale.

Safety information must not be conveyed by colour alone.

Warning symbols should be used only where their meaning is defined and consistent.

Warnings should not be buried in long paragraphs or placed only at the end of a procedure.

Major warnings **MAY** be placed in a center aligned box with an all red boarder and no fill.

II.3.5 Job safety analysis and task risk assessments

See VII.1.0.1 for a blank example JSA.

A job safety analysis (JSA) **MUST** be completed for tasks that are new, non-routine, changed, potentially hazardous, or insufficiently covered by an existing approved procedure.

A JSA **MUST**

- identify the task and its location;
- identify the people involved and their roles;
- divide the task into logical steps;
- identify hazards associated with each step;
- describe possible consequences;
- identify existing controls;
- assess the initial risk;
- specify additional controls where required;
- assess the residual risk after applying the controls;
- identify required personal protective equipment;
- identify emergency, spill, or abnormal-condition arrangements; and
- record the names, signatures, and dates of the people who completed and approved the assessment.

Controls **MUST** be selected using the following order of preference:

1. elimination of the hazard;
2. substitution with a less hazardous material, method, or process;
3. engineering controls;
4. administrative controls and procedural controls; and
5. personal protective equipment.

Personal protective equipment **MUST** not be used as the only control where a more effective control is reasonably practicable.

A JSA **MUST** be reviewed when the task, equipment, materials, location, personnel, or conditions change. It **MUST** also be reviewed after an incident, near miss, control failure, or significant unexpected result.

II.3.6 Risk assessment matrix

Risk **MUST** be assessed using the likelihood and consequence scales in Tables 1 and 2. The risk score **MUST** be calculated by multiplying the likelihood score by the consequence score.

II.3.6.1 Likelihood scale

The likelihood scale is defined as follows.

Table 1: Likelihood scale

Score	Rating	Description
1	Rare	The event is unlikely to occur during the task or project.
2	Unlikely	The event could occur, but is not expected under normal conditions.
3	Possible	The event may occur at some time during the task or project.
4	Likely	The event is expected to occur in some circumstances.
5	Almost certain	The event is expected to occur frequently or repeatedly.

II.3.6.2 Consequence scale

The consequence scale is defined as follows.

Table 2: Consequence scale

Score	Rating	Description
1	Insignificant	No injury, negligible damage, and no significant disruption.
2	Minor	Minor injury or illness, minor damage, or short-term disruption.
3	Moderate	Medical treatment, significant damage, or disruption requiring management.
4	Major	Serious injury or illness, major damage, or extended disruption.
5	Catastrophic	Fatality, permanent disabling injury, multiple serious injuries, or major loss.

II.3.6.3 The Matrix

The consequence scale and likelihood scale then gives the matrix.

Table 3: Risk matrix

Risk Matrix	1 Insignificant	2 Minor	3 Moderate	4 Major	5 Catastrophic
1 Rare	1	2	3	4	5
2 Unlikely	2	4	6	8	10
3 Possible	3	6	9	12	15
4 Likely	4	8	12	16	20
5 Almost certain	5	10	15	20	25

Consequence score

1–4: Low The task may proceed with routine controls and normal supervision.

5–9: Moderate Additional controls **SHOULD** be considered. The responsible person **MUST** confirm that the risk is adequately controlled before work begins.

10–16: High Additional controls **MUST** be implemented before the task begins. Approval by the responsible supervisor **MUST** be obtained.

17–25: Extreme The task **MUST NOT** begin or continue until the risk has been reduced to an acceptable level and formally approved by the appropriate authority.

The risk assessment **MUST** record both the initial risk and the residual risk after controls have been applied. A lower residual score **MUST** not be claimed unless the additional controls are actually implemented and verified.

Where a risk cannot be reduced to an acceptable level, the task **MUST** be stopped and escalated to the responsible supervisor or safety authority.

II.3.7 Take 5 assessments

See VII.1.0.2 for an blank take 5 form.

A Take 5 assessment **MUST** be completed immediately before starting a task when a formal JSA is not required or when the conditions have changed since the JSA or procedure was completed.

The Take 5 assessment **MUST** require the worker to:

1. stop before starting the task;
2. look for hazards and changes in the work area;
3. assess the possible risk;
4. control the hazards; and
5. confirm that it is safe to proceed.

A Take 5 assessment **MUST** be repeated when the worker, task, equipment, materials, location, or conditions change. A worker **MUST** stop and obtain assistance if the risk cannot be controlled adequately.

Take 5 records **MUST** identify the task, date, location, person conducting the assessment, hazards identified, controls applied, and any required escalation or follow-up action.

II.3.8 Tables, figures, and equations

Give every table and figure a number and descriptive title.

Refer to each table or figure in the surrounding text.

Keep table headings visible if a table continues onto another page.

Do not use colour as the only way to distinguish table categories.

Align numbers consistently, especially decimal values.

Use sufficient cell padding and avoid overly dense tables.

Use diagrams only when they communicate something more clearly than text.

Ensure all figures have alternative text or a descriptive caption.

Avoid screenshots of text that could instead be searchable, selectable text.

II.3.9 Forms, records, and examples

Documents that explain or demonstrate the use of a form, record sheet, checklist, or template **MUST** include a clean, blank version of that form in Appendix A.

The example used in the main body **MAY** contain sample entries, annotations, instructions, or highlighting. The clean version in Appendix A **MUST**

- Contain no example data;
- Contain no instructional annotations unless they are part of the form itself;
- Retain all required fields, headings, signatures, dates, and document-control information;
- Be suitable for printing or electronic completion; and
- Use the same field names and layout as the example in the main body.

The example form **MAY** be of a different page size and orientation to the rest of the document.

Blank form pages do not require the following:

- Page numbering
- Headers
- Footers

If more than one form is included, the clean forms **MUST** be labelled.

All forms **MUST** be placed in Appendix A.

A clean form **MUST** be provided even when the example is completed electronically. Blank fields **MUST** be sufficiently large for the expected amount of information.

Forms **MUST** not rely solely on colour, shading, or annotations to communicate their purpose.

II.3.10 Accessibility and digital use

Use real heading levels rather than manually enlarged or bold text.

Use selectable text, not scanned pages, whenever possible.

Add descriptive alternative text to meaningful images.

Use descriptive link text rather than “click here.”

Ensure hyperlinks are distinguishable without relying only on colour.

Use a logical reading order.

Make the document usable at 200% zoom without losing essential information.

Use sufficient colour contrast for any permitted coloured content.

Include bookmarks and searchable metadata in the final document where feasible.

II.3.11 Document control

Every controlled SOP should include where applicable:

- Document title
- Document identifier
- Version or revision number
- Effective date

- Review date
- Author
- Technical reviewer
- Approver
- Approval date
- Superseded document information
- Page number in the form “Page X of Y,” if practical
- A revision-history table
- A statement identifying whether the copy is controlled or uncontrolled

Part III

Computer Standards

III.1 Scope and Responsibilities

III.1.1 Purpose

This document defines the minimum procedures and controls for managing the organization's computer systems, networks, applications, accounts, data, backups, and related infrastructure.

The purpose of these procedures is to:

- Protect the confidentiality, integrity, and availability of user systems and data
- Reduce the likelihood and impact of security incidents
- Ensure that systems are maintained, monitored, backed up, and recoverable
- Establish clear ownership and accountability for technology resources
- Provide consistent procedures for administration, maintenance, change, and retirement

III.1.2 Scope

These procedures apply to all systems and technology resources owned, operated, managed, or used on behalf of the user, including:

- Servers, workstations, laptops, and mobile devices
- Virtual machines, containers, hypervisors, and cloud resources
- Firewalls, routers, switches, wireless systems, VPNs, and other network equipment
- Operating systems, applications, databases, and directory services
- Email, file storage, collaboration, and hosted services
- User accounts, administrator accounts, service accounts, and emergency accounts
- user data, backup data, encryption keys, and recovery information
- Removable media and equipment used to access user systems
- Third-party systems that store, process, or transmit user data

These procedures apply any employees, contractors, temporary workers, volunteers, interns, consultants, vendors, and any other person who is authorized to access users systems.

Systems that cannot comply with a requirement **MUST** be documented and approved as an exception.

The exception record **MUST** identify the affected system, the reason for non-compliance, the risks involved, compensating controls, responsible owner, approval, and expiration or review date.

III.1.3 Management Responsibilities

Management is responsible for providing the authority, resources, and personnel required to operate systems securely.

Management **MUST**:

- Approve these procedures and significant changes to them
- Assign owners for systems, applications, data, and processes
- Ensure that identified risks are addressed or formally accepted
- Ensure that personnel receive appropriate training
- Support incident response and disaster recovery activities
- Ensure that critical systems have documented recovery priorities
- Review unresolved security, availability, and compliance issues

Management **MUST NOT** require personnel to bypass security controls merely for convenience or to meet an operational deadline without documenting and approving the associated risk.

III.1.4 System and Service Owners

Each system, application, service, and significant data collection **MUST** have a designated owner. The owner may delegate technical work but retains responsibility for the system's business purpose and risk.

System and service owners **MUST**:

- Define the purpose and criticality of the system
- Identify the data stored, processed, or transmitted
- Approve authorized users and access levels
- Ensure that the system is included in the asset inventory
- Define backup, retention, recovery, and availability requirements
- Approve significant configuration and access changes
- Review access and system status periodically
- Ensure that unsupported or obsolete systems are replaced, isolated, or retired
- Participate in recovery tests and incident investigations

A system owner **MUST** notify the appropriate administrator when a system's purpose, data, users, dependencies, or risk changes.

III.1.5 System Administrators

System administrators are responsible for the technical operation and maintenance of assigned systems.

Administrators **MUST**:

- Use individual administrator accounts
- Follow least-privilege and separation-of-duty requirements
- Maintain secure configurations
- Apply approved patches and updates
- Monitor system health, capacity, and security alerts
- Verify that backups are running and report failures

- Document significant changes and maintenance
- Protect credentials, keys, and administrative information
- Maintain current system documentation
- Report suspected compromise, data loss, or control failure promptly

Administrators **MUST NOT** use administrative accounts for routine email, web browsing, or other ordinary user activities unless technically necessary and approved.

Administrative actions **SHOULD** be logged. Logs **MUST NOT** contain passwords, private keys, recovery secrets, or other sensitive credential values.

III.1.6 Users

Users are responsible for protecting the accounts, devices, and information assigned to them.

Users **MUST**:

- Use only their own accounts unless an approved shared account is required
- Protect passwords, MFA devices, recovery codes, and other authentication information
- Lock or log out of devices when they are unattended
- Use user systems only for authorized purposes
- Protect user data from unauthorized access or disclosure
- Report suspected phishing, malware, lost devices, unauthorized access, or accidental disclosure promptly
- Follow approved procedures for storing, transmitting, and disposing of user information

Users **MUST NOT** install unauthorized software, disable security controls, share credentials, or connect unknown devices to user networks.

III.1.7 Information and Data Owners

Data owners are responsible for determining how information should be protected throughout its lifecycle.

Data owners **MUST**:

- Classify information according to its sensitivity
- Approve access based on business need
- Define retention and disposal requirements
- Identify backup and recovery requirements
- Review access periodically
- Report changes in legal, contractual, or business requirements

Data owners **SHOULD** work with system owners and administrators to ensure that technical controls match the sensitivity and importance of the data.

III.1.8 Security and Privacy Responsibilities

The person or team responsible for security oversight **SHOULD**:

- Maintain security policies and procedures
- Coordinate risk assessments and security reviews
- Review security alerts and reported incidents
- Coordinate incident response
- Track exceptions and corrective actions
- Provide security awareness training
- Review the effectiveness of security controls

Security responsibilities may be assigned to an administrator or manager in a small organization, but the assignment **MUST** be documented. A person should not approve their own high-risk access or changes where separation of duties is reasonably practicable.

III.1.9 Third-Party Responsibilities

Vendors and contractors with access to user systems or data **MUST**:

- Use only approved accounts and access methods
- Protect user information from unauthorized disclosure
- Follow applicable security and change-management procedures
- Use MFA where supported or required
- Report suspected incidents promptly
- Return or securely delete user information when access ends

Third-party access **MUST** be limited to the required systems, time period, and permissions. Access **MUST** be reviewed and removed when the work is complete or the relationship ends.

III.1.10 Responsibility Assignment

Responsibilities for critical systems and processes **MUST** be assigned to named roles or individuals. The user **SHOULD** maintain a responsibility register containing:

- System or process name
- Business owner
- Technical owner
- Primary administrator
- Backup administrator
- Data classification
- Recovery priority
- Vendor or support contact, if applicable

- Last review date

No critical system **SHOULD** depend on only one person's knowledge or availability. At least one trained backup administrator **SHOULD** be identified for each critical system.

III.1.11 Review and Enforcement

These procedures **SHOULD** be reviewed at least annually and whenever there is a significant change to systems, personnel, business operations, legal requirements, or security risks.

Violations **MUST** be reported to management or the designated security contact. Corrective action may include additional training, removal of access, disciplinary action, technical remediation, or other measures appropriate to the risk and circumstances.

III.2 Data classification and encryption

III.2.1 Purpose

This section defines requirements for classifying, handling, storing, transmitting, and protecting organizational information. The purpose is to ensure that information receives protection appropriate to its sensitivity, business importance, legal requirements, and potential impact if disclosed, altered, lost, or destroyed.

III.2.2 Scope

These requirements apply to all information created, received, stored, processed, transmitted, or disposed of by the organization, regardless of format or location.

This includes information stored on:

- Servers, workstations, laptops, and mobile devices
- Cloud services, hosted applications, and virtual systems
- Databases, file shares, email systems, and collaboration platforms
- Backup systems and removable media
- Paper records and printed documents
- Third-party systems used to store or process organizational information

III.2.3 Information Classification

Information **MUST** be assigned a classification by the information owner. The classification **MUST** be based on the sensitivity of the information and the potential impact of unauthorized disclosure, modification, loss, or destruction.

The organization **SHOULD** use the following classification levels:

- **Public:** Information approved for public release and disclosure. Unauthorized modification may still require protection.
- **Internal:** Information intended for use by authorized personnel and trusted third parties. Unauthorized disclosure may cause limited operational or reputational harm.
- **Confidential:** Information that requires restricted access because unauthorized disclosure, modification, or loss could cause significant harm.

- **Restricted:** Highly sensitive information requiring the strongest available safeguards. Examples include authentication secrets, encryption keys, sensitive personal information, payment information, and security investigation data.

Information **MUST** be classified at creation or when it is first received. If the classification is uncertain, the information **MUST** be handled using the higher classification until the information owner makes a determination.

III.2.4 Handling Requirements

Information **MUST** be accessed only by individuals, systems, and services with an authorized business need.

Information owners **MUST** define appropriate requirements for:

- Access authorization
- Storage locations
- Transmission methods
- Sharing with internal and external parties
- Retention periods
- Backup and recovery
- Disposal and destruction

Confidential and Restricted information **MUST NOT** be stored in publicly accessible locations or transmitted through unapproved services.

Restricted information **MUST** be protected using access controls, encryption, monitoring, and other safeguards appropriate to the risk.

Information **SHOULD** be labeled where practical. Labels may be applied to documents, email messages, database records, file shares, removable media, and other storage locations.

III.2.5 Access Control

Access to Confidential and Restricted information **MUST** be granted according to least privilege and business need.

Access permissions **MUST**:

- Be approved by the information owner or delegated authority
- Be assigned to individual accounts whenever possible
- Be reviewed periodically
- Be removed when no longer required
- Be removed or changed when a person's role changes
- Be removed when employment, contract, or authorization ends

Shared accounts **SHOULD** not be used to access Confidential or Restricted information unless technically necessary and formally approved.

III.2.6 Encryption

Confidential and Restricted information **MUST** be encrypted when transmitted across untrusted networks.

Restricted information **MUST** be encrypted when stored on portable devices, removable media, or systems that are not physically controlled by the organization.

Encryption keys **MUST** be protected separately from the information they protect. Encryption keys **MUST NOT** be stored in plaintext alongside encrypted data unless the arrangement is specifically designed and approved for key management.

Encryption keys **MUST** be:

- Accessible only to authorized personnel and systems
- Protected against unauthorized modification or disclosure
- Backed up when necessary for recovery
- Rotated or replaced when compromise is suspected
- Retired when no longer required

Passwords, API keys, private keys, recovery codes, and similar authentication values **MUST** be stored using approved secret-management methods. They **MUST NOT** be stored in source code, ordinary documents, tickets, email, or publicly accessible repositories.

III.2.7 Transmission and Sharing

Confidential and Restricted information **MUST** be transmitted only through approved methods.

Before sharing information with a third party, the responsible owner **MUST** verify:

- The recipient is authorized to receive the information
- The recipient requires the information for a legitimate purpose
- The transmission method provides appropriate protection
- Contractual or legal requirements have been addressed
- The information is limited to the minimum necessary

Information sent by email **SHOULD** be encrypted or protected using an approved secure-sharing mechanism when the classification or risk requires it.

Sensitive information **MUST NOT** be sent to personal email accounts, unapproved file-sharing services, or unauthorized applications.

III.2.8 Backup and Recovery

Backups containing Confidential or Restricted information **MUST** be protected at a level equal to or greater than the original information.

Backups **MUST** be subject to:

- Access restrictions
- Encryption where appropriate
- Retention requirements

- Monitoring and failure reporting
- Periodic recovery testing
- Secure disposal when no longer required

Recovery copies of encryption keys and other secrets **MUST** be protected against unauthorized access and loss.

III.2.9 Disposal

Information **MUST** be securely disposed of when it is no longer required, subject to legal, contractual, operational, and retention requirements.

Disposal methods **MUST** be appropriate to the media and classification. These methods may include:

- Secure deletion
- Cryptographic erasure
- Physical destruction
- Shredding of paper records
- Sanitization or destruction of removable media

Simply deleting a file or moving it to a recycle bin **MUST NOT** be considered sufficient disposal for Confidential or Restricted information unless an approved secure-deletion process is used.

III.2.10 Incident Reporting

Suspected loss, unauthorized access, accidental disclosure, incorrect classification, or compromise of Confidential or Restricted information **MUST** be reported promptly according to the incident response procedures.

The report **SHOULD** include the affected information, systems, individuals, time period, suspected cause, and actions already taken.

III.2.11 Review

Information owners **MUST** review classifications when the sensitivity, use, legal requirements, business value, or risk associated with information changes.

Classification and encryption requirements **SHOULD** be reviewed at least annually and whenever a significant system, process, vendor, or regulatory change occurs.

III.3 Asset inventory

The organization **MUST** maintain an accurate inventory of technology assets that are owned, leased, managed, operated, or used to access organizational systems or data.

Each asset **MUST** have a unique identifier that allows it to be distinguished from other assets throughout its lifecycle. Physical assets **SHOULD** be labeled with an organizational asset tag where practical.

The asset inventory **MUST** include, where applicable:

- Servers, workstations, laptops, tablets, and mobile devices
- Virtual machines, containers, hypervisors, and cloud resources

- Firewalls, routers, switches, wireless access points, and VPN equipment
- Storage systems, backup systems, and removable media
- Printers, scanners, cameras, and other network connected devices
- Internet facing systems and externally hosted services
- Devices used by employees, contractors, vendors, and other authorized users
- Equipment used to store, process, transmit, or access organizational data

Each inventoried asset **MUST**, to the extent technically and operationally feasible, have the following information recorded:

- Asset name or hostname
- Asset type and description
- Hardware manufacturer, model, and serial number
- Assigned user, department, or responsible role
- Business or system owner
- Physical location or hosting environment
- Internet Protocol address, media access control address, or other identifier
- Operating system or firmware, where applicable
- Data classification and types of data handled
- Criticality and recovery priority
- Related system, service, or business process
- Support status and warranty information
- Acquisition date and expected replacement date
- Current status, such as active, inactive, lost, under repair, or retired
- Date of last inventory review

Asset owners **MUST** ensure that asset information remains accurate and current. New assets **MUST** be recorded before being placed into production or connected to organizational networks, unless an emergency deployment is authorized and the asset is documented as soon as practicable.

Assets **MUST** be assigned to a responsible owner or role. The owner **MUST** be accountable for the asset's approved use, security requirements, maintenance, and retirement.

Assets **MUST** be classified according to their importance and the sensitivity of the data they store, process, or transmit. Critical assets **MUST** be identified so that they can receive appropriate protection, monitoring, backup, and recovery planning.

Unauthorized, unknown, or unmanaged assets **MUST** be investigated. An asset that cannot be approved or associated with a responsible owner **MUST** be isolated, removed, or otherwise restricted until its status is resolved.

The organization **SHOULD** use automated discovery, endpoint management, cloud management, network monitoring, or similar technical controls to identify assets that are missing from the inventory.

The asset inventory **MUST** be reviewed:

- At least annually
- After significant changes to systems or infrastructure
- During major hardware or software deployments
- After mergers, acquisitions, office moves, or organizational changes
- Following the loss, theft, or disposal of equipment
- Following a security incident that may affect asset ownership or status

Critical assets **SHOULD** be reviewed more frequently based on their risk and operational importance.

Asset records **MUST** be updated when equipment is reassigned, relocated, modified, replaced, lost, stolen, or retired. Changes to ownership, responsible personnel, network location, operating system, or data classification **MUST** be recorded promptly.

Lost or stolen assets **MUST** be reported to management or the designated security contact promptly. The organization **MUST**, where technically possible, disable accounts, revoke credentials, remove access tokens, enable remote lock or wipe, and assess whether organizational data may have been exposed.

Assets that are no longer required **MUST** be securely decommissioned. Before disposal, reuse, return, or transfer, organizational data **MUST** be removed using an approved sanitization method appropriate to the media and sensitivity of the information.

Asset disposal or retirement records **SHOULD** include:

- Asset identifier
- Date of disposal or retirement
- Reason for disposal or retirement
- Sanitization or destruction method
- Person or vendor performing the work
- Transfer, recycling, return, or destruction details
- Approval, where required

Third-party or cloud-hosted assets that store, process, or transmit organizational data **MUST** be included in the inventory or linked to an inventory record. The organization **MUST** maintain sufficient information to identify the service provider, service owner, data handled, access method, and contract or subscription status.

The asset inventory **SHOULD** be protected from unauthorized modification or disclosure. Access **MUST** be limited to personnel with a legitimate business need, and changes to critical inventory records **SHOULD** be logged.

III.4 Software inventory

The organization **MUST** maintain an accurate inventory of software used on organizational systems or to access organizational data.

The organization **SHOULD** maintain an approved software list identifying software that is authorized for general use, restricted use, or use only on specifically approved systems.

Software **SHOULD** be assigned a status such as approved, approved with restrictions, pending review, prohibited, unsupported, or retired.

The software inventory **MUST** include, where applicable:

- Operating systems and system components
- Applications and productivity software
- Security, backup, monitoring, and management tools
- Databases, runtimes, libraries, frameworks, and dependencies
- Firmware and embedded software
- Scripts, automation tools, and internally developed software
- Software-as-a-service applications and cloud services
- Mobile applications used to access organizational systems or data
- Container images and packages
- Browser extensions and add-ons

Each software record **MUST**, to the extent applicable, include:

- Software name and purpose
- Publisher, developer, or service provider
- Version and edition
- Installation location or associated system
- Software owner and technical administrator
- License type, license quantity, and renewal date
- Data classification and types of data handled
- Business criticality
- Dependencies and integrations
- Support status and end-of-support date
- Approved source or distribution method
- Date of last review

Software **MUST** be approved before it is installed, deployed, or used to process organizational data. Approval **MUST** consider the software's purpose, security features, licensing requirements, privacy and data-handling practices, compatibility, support status, and operational risk.

Users **MUST NOT** install or use unauthorized software on organizational systems. Users **MUST NOT** use software obtained from untrusted or unofficial sources unless it has been reviewed and approved by an authorized administrator.

Software installation **MUST** be limited to authorized personnel or approved management systems. Administrative privileges **SHOULD** not be granted to users solely to permit software installation.

The organization **MUST** maintain a process for identifying unsupported, obsolete, vulnerable, or end-of-life software. Unsupported software **MUST** be upgraded, replaced, isolated, or removed. If immediate remediation is not possible, the system owner **MUST** document and approve an exception that identifies the risk, compensating controls, responsible owner, and expiration or review date.

Software **MUST** be kept reasonably current through approved patches, updates, and upgrades. Security updates **MUST** be prioritized according to the severity of the vulnerability, exposure of the affected system, availability of mitigations, and business criticality.

Software updates **SHOULD** be tested before broad deployment when testing is practical and the risk of incompatibility is significant. Emergency security updates may be deployed without standard testing when delaying deployment would create a greater risk.

The organization **SHOULD** use centralized software deployment, endpoint management, package management, or equivalent technical controls to:

- Identify installed software
- Detect unauthorized software
- Track software versions
- Deploy approved updates
- Remove unsupported or unauthorized software
- Report systems that do not meet software requirements

Open-source software, libraries, packages, and external dependencies **MUST** be obtained from approved sources and maintained at supported versions where feasible. Internally developed software **MUST** identify its significant external dependencies and **SHOULD** be reviewed for known vulnerabilities before release.

Software used to handle confidential, regulated, or otherwise sensitive information **MUST** be evaluated for appropriate access controls, encryption, logging, retention, and data-sharing behavior.

Software licenses **MUST** be managed in accordance with applicable licensing terms. The organization **MUST** maintain sufficient records to demonstrate that software use is authorized and that license limits are not exceeded.

Software-as-a-service applications **MUST** have an identified business owner and technical or administrative contact. Before use, the organization **SHOULD** evaluate the service's authentication, access control, data protection, backup, logging, incident notification, termination, and data-return capabilities.

Software inventory records **MUST** be reviewed:

- At least annually
- Before and after major software deployments
- When software is replaced, upgraded, or retired
- When a vendor ends support for a product
- After a significant vulnerability or security incident
- When licensing, contractual, or regulatory requirements change

Software that is no longer approved, supported, required, or licensed **MUST** be removed or formally excepted. Associated accounts, integrations, credentials, scheduled tasks, service connections, and stored data **MUST** be reviewed and disabled or removed as appropriate.

Retired software records **SHOULD** include:

- Software name and version
- Systems or users affected
- Retirement date
- Reason for retirement
- Replacement software, if applicable

- Data migration or disposal actions
- Removal or decommissioning approval

Changes to critical software installations, configurations, integrations, and versions **SHOULD** be documented. Significant changes **MUST** follow the organization's change-management procedures.

III.5 Secure configuration

III.5.1 Purpose

Secure configuration procedures establish and maintain approved security settings for systems, applications, network devices, cloud resources, and other technology assets. Secure configurations reduce the likelihood of unauthorized access, data loss, malware infection, service disruption, and exploitation of known weaknesses.

III.5.2 Configuration Standards

Each supported system type **MUST** have a documented secure configuration standard appropriate to its purpose, risk, technology, and data classification.

Secure configuration standards **SHOULD** address, where applicable:

- Operating system and firmware versions
- Supported software versions
- Authentication and authorization settings
- Password and multifactor authentication requirements
- User, administrator, service, and guest accounts
- Network services, ports, and protocols
- Firewall and access-control rules
- Encryption settings
- Logging and monitoring settings
- Malware and endpoint protection
- Automatic updates and patching
- Backup and recovery settings
- Time synchronization
- Physical security settings
- Remote access settings
- Data storage, retention, and disposal settings

Configuration standards **MUST** identify settings that are required, prohibited, or permitted only with documented approval.

III.5.3 Baseline Configurations

Systems **MUST** be configured using an approved baseline before being placed into production or connected to organizational networks.

A baseline configuration **MUST** include, as appropriate:

- The approved operating system, application, or firmware version
- Required security updates
- Approved services and network ports
- Required security controls
- Approved administrator and service accounts
- Logging and monitoring requirements
- Backup requirements
- Configuration ownership
- Date of approval and most recent review

Unnecessary services, applications, accounts, protocols, ports, and network interfaces **MUST** be disabled or removed.

Default passwords, default administrator accounts, sample applications, and vendor-provided demonstration content **MUST** be removed, disabled, or changed before production use.

III.5.4 Configuration Management

Configuration changes **MUST** be authorized, tested where reasonably practicable, documented, and reviewed according to the change-management procedures.

Configuration changes **MUST** identify:

- The affected system or device
- The requested change
- The reason for the change
- The person requesting and approving the change
- The implementation date
- The expected effect on security and availability
- Any testing or validation performed
- The rollback or recovery procedure

Emergency changes may be implemented before normal approval when necessary to protect systems, data, or users. Emergency changes **MUST** be documented and reviewed as soon as reasonably practicable.

Configuration files, scripts, templates, and infrastructure-as-code definitions **SHOULD** be stored in an approved location with access controls and version history.

Configuration files **MUST NOT** contain passwords, private keys, API keys, recovery codes, or other secrets in plaintext unless specifically authorized and protected by appropriate controls.

III.5.5 Security Hardening

Administrators **MUST** apply security-hardening measures appropriate to the system and its risk.

Systems **MUST**, where supported:

- Require authenticated administrative access
- Restrict administrative access to authorized personnel
- Use encrypted management protocols
- Disable insecure or obsolete protocols
- Restrict remote management to approved networks or access methods
- Enable logging for authentication and administrative activity
- Synchronize system time with an approved time source
- Apply supported security updates
- Use endpoint protection where appropriate
- Protect sensitive data using approved encryption

Administrative interfaces **SHOULD** not be exposed directly to the public Internet unless there is a documented business requirement and compensating controls.

Shared administrative accounts **SHOULD** not be used. When a shared account is technically necessary, its use **MUST** be approved, monitored, and reviewed.

III.5.6 Configuration Review

Configurations **MUST** be reviewed periodically and after significant changes to the system, software, network, threat environment, or business requirements.

Configuration reviews **SHOULD** verify:

- Compliance with the approved baseline
- Removal or disabling of unnecessary services and accounts
- Correct application of access controls
- Current patch and firmware status
- Correct logging and monitoring
- Correct backup and recovery settings
- Use of approved encryption
- Removal of unauthorized software or configuration changes

Critical systems **SHOULD** be reviewed at least annually. Internet-facing systems, security devices, and systems containing sensitive information **SHOULD** be reviewed more frequently based on risk.

Automated configuration assessment tools **SHOULD** be used where reasonably practicable.

III.5.7 Configuration Exceptions

A system that cannot meet an approved configuration requirement **MUST** have a documented exception.

The exception record **MUST** identify:

- The affected system
- The configuration requirement that cannot be met
- The reason for the exception
- The risks created by the exception
- Compensating controls
- The responsible system owner
- The approving authority
- The expiration or review date

Exceptions **MUST** be reviewed before expiration and closed when the affected system is brought into compliance, replaced, isolated, or retired.

III.5.8 Responsibility

System owners are responsible for ensuring that systems under their control have approved and current secure configurations.

Administrators are responsible for implementing, maintaining, documenting, and reviewing configurations.

Users **MUST NOT** modify security settings, install unauthorized software, disable security controls, or otherwise alter managed systems without authorization.

Configuration deviations, suspected tampering, and unauthorized software **MUST** be reported promptly to the appropriate administrator or security contact.

III.6 Patch and vulnerability management

III.6.1 Purpose

Patch and vulnerability-management procedures identify, evaluate, prioritize, remediate, and monitor weaknesses in systems, applications, devices, networks, cloud resources, and other technology assets.

The purpose of these procedures is to reduce the likelihood that vulnerabilities will be exploited and to ensure that security updates are applied in a timely and controlled manner.

III.6.2 Asset Coverage

Patch and vulnerability management **MUST** apply to all supported technology resources, including:

- Servers, workstations, laptops, and mobile devices
- Operating systems, applications, databases, and middleware
- Network devices, firewalls, wireless systems, and VPN equipment
- Virtual machines, containers, hypervisors, and cloud resources
- Security appliances and management platforms

- Firmware, drivers, libraries, and third-party components
- Internet-facing systems and externally hosted services

Systems and applications **MUST** be included in the asset inventory so that their ownership, software versions, support status, and patch requirements can be tracked.

Unsupported or end-of-life systems **MUST** be identified and documented. Such systems **MUST** be replaced, upgraded, isolated, or retired as soon as reasonably practicable.

III.6.3 Vulnerability Identification

The organization **MUST** use appropriate sources to identify vulnerabilities and security updates affecting its systems.

Vulnerability information may be obtained from:

- Software and hardware vendors
- Operating system and application security advisories
- Vulnerability databases
- Security monitoring services
- Internal vulnerability scans
- Penetration tests and security assessments
- Incident investigations
- Managed service providers and security partners

Administrators and system owners **MUST** monitor for vulnerabilities affecting systems under their responsibility.

Vulnerability scans **SHOULD** be performed periodically on internal and externally accessible systems. Internet-facing systems **SHOULD** be scanned more frequently based on their exposure and risk.

III.6.4 Vulnerability Assessment

Identified vulnerabilities **MUST** be evaluated according to their severity, exploitability, affected assets, exposure, data sensitivity, and potential business impact.

The assessment **SHOULD** consider:

- The severity assigned by the vendor or vulnerability source
- Whether the vulnerability is actively being exploited
- Whether public exploit code is available
- Whether the affected system is accessible from the Internet
- The sensitivity and criticality of the affected system
- The availability of a patch or other remediation
- Existing compensating controls
- The operational risk of applying the remediation

Vulnerabilities **MUST** be prioritized based on risk rather than severity alone.

III.6.5 Patch Priorities

Unless a documented exception is approved, patches and vulnerability remediations **SHOULD** be addressed according to the following priorities:

- Critical vulnerabilities affecting Internet-facing or mission-critical systems **SHOULD** be remediated as soon as possible.
- High-risk vulnerabilities **SHOULD** be remediated within a defined period based on organizational risk tolerance.
- Medium-risk vulnerabilities **SHOULD** be remediated during the next appropriate maintenance cycle.
- Low-risk vulnerabilities **SHOULD** be addressed through routine maintenance or other planned remediation.

Vulnerabilities known to be actively exploited **MUST** receive urgent attention regardless of their original severity rating.

The organization **MUST** define target remediation timeframes for each risk level. Missed remediation timeframes **MUST** be documented and escalated to the system owner or responsible manager.

III.6.6 Patch Testing

Patches **SHOULD** be tested before deployment when testing is reasonably practicable and the risk of testing is lower than the risk of immediate deployment.

Testing **SHOULD** verify:

- The system remains operational
- Required applications and services continue to function
- Security controls remain enabled
- Business-critical integrations continue to operate
- Backups and recovery procedures remain available

Testing may be limited or skipped when a vulnerability is actively exploited, the affected system is highly exposed, or the vendor identifies the update as an urgent security fix.

The reason for bypassing normal testing **MUST** be documented.

III.6.7 Patch Deployment

Patches **MUST** be obtained from approved and trusted sources.

Patches **MUST** be applied using approved procedures and tools.

Administrators **MUST** verify, where technically practicable, that:

- The patch is intended for the affected system
- The patch was obtained from an approved source
- The patch installation completed successfully
- The system restarted or completed any required post-installation tasks
- The vulnerability or outdated version is no longer present

Automatic updates **SHOULD** be enabled where they are supported and appropriate for the system.

Security updates **MUST** not be permanently deferred merely for convenience or to avoid routine maintenance.

III.6.8 Emergency Remediation

Emergency remediation may include expedited patching, temporary isolation, disabling an affected service, restricting network access, applying a vendor workaround, or taking the affected system offline.

Emergency remediation **MUST** be considered when:

- A vulnerability is actively exploited
- A critical system is exposed to an untrusted network
- Sensitive information may be accessed through the vulnerability
- Exploit code is publicly available
- No acceptable compensating control is available

Emergency actions **MUST** be documented and reviewed after implementation.

III.6.9 Verification and Reporting

Patch and vulnerability remediation **MUST** be verified after deployment.

Verification may include:

- Reviewing patch-management reports
- Checking installed software and firmware versions
- Performing follow-up vulnerability scans
- Reviewing system logs
- Confirming that required services remain operational
- Obtaining confirmation from the system owner

Patch and vulnerability-management records **MUST** identify the affected asset, vulnerability or update, risk rating, remediation action, responsible person, date identified, date remediated, and verification result.

Management **SHOULD** receive periodic reports showing outstanding vulnerabilities, overdue patches, unsupported systems, and significant remediation risks.

III.6.10 Exceptions and Compensating Controls

A patch or vulnerability that cannot be remediated within the required timeframe **MUST** have a documented exception.

The exception record **MUST** include:

- The affected system and vulnerability
- The reason remediation cannot be completed
- The risks involved
- Compensating controls
- The responsible system owner
- The approving authority

- The planned remediation date
- The expiration or review date

Compensating controls may include network isolation, access restrictions, application allowlisting, additional monitoring, disabling vulnerable functionality, or increased logging.

Exceptions **MUST** be reviewed periodically and closed when remediation is completed or the affected system is retired.

III.7 Account and access management

III.7.1 Purpose

Account and access-management procedures ensure that access to systems, applications, networks, devices, and data is limited to authorized users and services based on business need.

Access **MUST** be granted, used, reviewed, modified, and removed in a controlled and documented manner.

III.7.2 Account Requirements

Each person **MUST** use an individually assigned account for normal system and application access.

Individual accounts **MUST** be used to support accountability, auditing, access review, and incident investigation.

Accounts **MUST** be associated with a responsible person, role, service, or system.

Accounts **MUST** have an owner and a defined purpose. Unowned, unidentified, or unnecessary accounts **MUST** be disabled or removed.

Users **MUST NOT** share passwords, authentication devices, recovery codes, API keys, or other authentication information.

Shared accounts **SHOULD** not be used. When a shared account is required for technical or operational reasons:

- The account **MUST** have a documented business purpose
- Use of the account **MUST** be approved by the system owner
- Access **MUST** be limited to authorized personnel
- Activity **MUST** be logged where technically practicable
- The account credentials **MUST** be changed when an authorized user leaves the role
- The account **MUST** be reviewed periodically

III.7.3 Access Requests and Approval

Access **MUST** be approved before it is provided.

Access requests **MUST** identify:

- The person or service requesting access
- The system, application, network, or data requested
- The requested role or permission level
- The business purpose

- The requested start date and, where applicable, end date
- The approving manager or system owner

Access **MUST** be based on the principles of least privilege and need to know.

Users **MUST** receive only the access required to perform their assigned duties.

Access to sensitive, critical, administrative, or financial systems **MUST** require approval from the appropriate system or data owner.

High-risk access **SHOULD** require approval from more than one authorized person where separation of duties is reasonably practicable.

III.7.4 Privileged Access

Privileged access includes administrative, root, domain, database, cloud-management, security-management, and other access capable of changing system configurations, permissions, security controls, or sensitive data.

Privileged access **MUST** be restricted to authorized administrators and other personnel with a documented business requirement.

Administrators **MUST** use separate privileged accounts for administrative activities and ordinary accounts for routine work.

Privileged accounts **MUST NOT** be used for routine email, web browsing, or other ordinary user activities unless technically necessary and approved.

Privileged access **SHOULD** use multifactor authentication and approved secure management methods.

Privileged access **MUST** be logged where technically practicable. Administrative logs **MUST** record enough information to identify the account, action, affected system, and date and time.

Privileged access **MUST** be reviewed periodically and after changes in responsibilities.

III.7.5 Authentication

Systems must use approved authentication controls appropriate to the sensitivity and risk of the system.

Multifactor authentication **MUST** be enabled for:

- Administrative and privileged accounts
- Remote access
- Cloud-management interfaces
- Access to sensitive or regulated information
- Systems where multifactor authentication is supported and required by the system owner

Authentication credentials **MUST** be protected from unauthorized disclosure.

Passwords **MUST** comply with the password-management requirements in this document.

Systems **SHOULD** prevent the reuse of recently used passwords, limit repeated failed authentication attempts, and require reauthentication after an appropriate period of inactivity.

Recovery codes, backup authentication methods, and emergency credentials **MUST** be protected to the same extent as passwords.

III.7.6 Account Provisioning

New accounts **MUST** be created only after the required approval has been obtained.

Before an account is created, the administrator **SHOULD** verify:

- The user's identity or service ownership
- The business purpose
- The requested access level
- The approving authority
- Any start date, expiration date, or access limitations

Accounts for temporary workers, contractors, vendors, interns, and other non-permanent users **MUST** have an expiration date or scheduled review date.

Service accounts **MUST** have a documented owner, purpose, required permissions, and credential-management method.

Service accounts **MUST NOT** be used for interactive logins unless technically required and approved.

III.7.7 Changes to Access

Changes to a user's role, responsibilities, employment status, contract, or system assignment **MUST** result in a review of that user's access.

Access that is no longer required **MUST** be removed promptly.

Administrators **MUST** not increase permissions merely to resolve an operational issue without documenting and approving the change.

Temporary elevated access **MUST** have a defined duration and **MUST** be removed when the approved period ends.

III.7.8 Account Termination

User access **MUST** be disabled or removed when employment, contract, volunteer service, or other authorization ends.

Termination procedures **MUST** address, as applicable:

- Network and application accounts
- Privileged and administrative accounts
- Remote-access accounts
- Email and collaboration accounts
- Cloud and vendor accounts
- Physical access credentials
- Company-owned devices
- Tokens, keys, certificates, and authentication devices
- Shared-account passwords known to the departing person

For planned terminations, access removal **MUST** occur no later than the end of the person's authorization.

For urgent or involuntary terminations, access **MUST** be removed or suspended immediately when directed by authorized management.

III.7.9 Access Reviews

Access rights **MUST** be reviewed periodically by the appropriate manager, system owner, or data owner.

Access reviews **SHOULD** confirm:

- The user or service still requires access
- The assigned permissions are appropriate
- Privileged access remains necessary
- Former users and inactive accounts have been removed
- Temporary access has expired
- Service accounts have current owners
- Shared accounts remain necessary and controlled

Critical systems, privileged accounts, and access to sensitive information **SHOULD** be reviewed at least quarterly.

Other accounts and access rights **SHOULD** be reviewed at least annually or more frequently based on risk.

Review results **MUST** be documented, including the reviewer, date, systems reviewed, identified issues, and corrective actions.

III.7.10 Inactive and Dormant Accounts

Accounts that are no longer required **MUST** be disabled or removed.

Accounts that have not been used for a defined period **SHOULD** be disabled automatically where technically practicable.

Dormant accounts **MUST** be reviewed before being reactivated.

Default, test, demonstration, and guest accounts **MUST** be disabled or removed unless there is a documented business requirement.

III.7.11 Emergency and Break-Glass Accounts

Emergency or break-glass accounts may be used only when normal administrative access is unavailable or insufficient to respond to an urgent operational or security need.

Emergency accounts **MUST**:

- Have a documented purpose and owner
- Be protected using strong credentials
- Be restricted to authorized personnel
- Be monitored and logged where technically practicable
- Be tested periodically
- Be reviewed after every use
- Have their credentials changed after use when appropriate

Use of an emergency account **MUST** be documented, including the reason, user, time, actions performed, and outcome.

III.7.12 Third-Party Access

Third-party access **MUST** be approved before it is enabled.

Third-party access **MUST** be limited to:

- The systems and data required for the approved work
- The minimum permissions required
- The approved time period
- Approved connection methods

Third-party access **MUST** use individual accounts where technically practicable.

Vendor and contractor accounts **MUST** be disabled or removed when the work is complete or the relationship ends.

Third-party access **MUST** be reviewed periodically and after significant changes to the contract, service, system, or risk.

III.7.13 Account and Access Records

Account and access records **MUST** be maintained for systems that require formal access management.

Records **SHOULD** include:

- Account name and type
- Account owner
- User, service, or vendor associated with the account
- System or application
- Assigned role and permissions
- Approval information
- Creation date
- Expiration or review date
- Last access review
- Account status

Access records **MUST** be protected from unauthorized modification and disclosure.

III.8 Password Management

III.8.1 Password Hashing and Encryption

User passwords **MUST NOT** be stored in plain text, encoded form, or a reversible format.

Passwords used for authentication **SHOULD** be stored using a unique, random salt and a memory-hard password-hashing function such as Argon2id. The work factor **SHOULD** be selected based on system performance and reviewed periodically as computing power increases.

The password record **SHOULD** include the hashing algorithm, version, salt, and work-factor parameters so that passwords can be migrated to stronger parameters in the future.

Passwords **MUST NOT** be hashed using fast general-purpose functions such as MD5, SHA-1, or unsalted SHA-256.

Secrets that must later be recovered, such as service passwords, API keys, and encryption keys, **MUST** be encrypted using an approved authenticated encryption method. Encryption keys **MUST** be protected separately from the encrypted secrets, preferably using a key-management system, HSM, or equivalent protected storage.

III.8.2 Access Control and Accountability

Access to stored credentials **MUST** follow least privilege and need-to-know principles.

Each person **SHOULD** use an individual account. Shared administrator accounts **SHOULD** be avoided; where they are unavoidable, their use **MUST** be logged and reviewed.

Administrative access to the password manager and infrastructure credentials **SHOULD** require MFA, preferably using a phishing-resistant authenticator.

Access **MUST** be removed promptly when personnel change roles or leave the organization.

Credential access, creation, modification, export, and recovery events **SHOULD** be logged and reviewed. Logs **MUST NOT** contain passwords, recovery secrets, private keys, or other secret values.

III.8.3 Credential Lifecycle

Credentials **MUST** have an identified owner, purpose, system, and classification.

Credentials **SHOULD** be generated by an approved password manager or secrets-management system rather than manually chosen.

Default passwords **MUST** be changed before a system is placed into service.

Credentials **MUST** be rotated when they are exposed, suspected of compromise, used by departing personnel, or transferred between custodians.

Unused, obsolete, and duplicate credentials **MUST** be disabled or deleted. Service-account credentials **SHOULD** be rotated automatically where practical, and their permissions **SHOULD** be limited to the minimum required tasks.

III.8.4 Password and Secret Recovery

Recovery procedures **MUST** be documented and tested periodically.

Recovery access **SHOULD** require approval from at least two authorized people for critical systems. Recovery codes and backup keys **SHOULD** be one-time or tightly controlled where the system supports this.

A recovery procedure **SHOULD** specify:

- Who may authorize recovery
- How the identity of the requester is verified
- Which records or keys are required
- How emergency access is logged
- How credentials are changed after recovery
- How exposed or superseded credentials are revoked
- How the incident is documented and reviewed

III.8.5 Physical Password Storage

Physical recovery records should be treated as emergency recovery.

They **SHOULD NOT** contain every user's password.

They **SHOULD** be stored in a secure location and access should be limited to authorized personnel only.

They **SHOULD** include:

- Firewall/router recovery credentials
- Proxmox or hypervisor emergency credentials
- Password manager administrator recovery information
- Backup encryption keys
- VPN recovery information
- Identity-server emergency administrator credentials
- Database administrator recovery credentials
- Recovery codes for critical MFA accounts
- A current network diagram and IP/VLAN documentation
- Instructions for restoring the password manager and backups

DO NOT put ordinary user passwords, private SSH keys, API keys, or unencrypted database passwords in a shared filing cabinet.

Store routine credentials in a password manager with individual access and MFA. The physical copy should contain only the minimum secrets needed to recover infrastructure.

Physical recovery records **SHOULD** be sealed in tamper-evident envelopes or containers and stored in a fire-resistant, access-controlled location.

The organization **MUST** maintain an inventory of physical recovery records, including their location, responsible custodians, creation date, and last review date.

Physical recovery records **MUST** be reviewed at least annually and whenever infrastructure, personnel, or recovery procedures change.

Superseded records **MUST** be destroyed securely. Sensitive paper records should be cross-cut shredded, pulped, or destroyed by an approved secure disposal provider.

The physical records **MUST** not be photographed, scanned, copied, or stored in an ordinary shared office file without authorization.

III.8.5.1 Split custody

For the highest risk secrets, use split custody:

- Divide a recovery secret or key into two parts so that no single person can use it alone.
- This is useful for root recovery, backup decryption, or the password manager emergency account.

At least two authorized custodians **SHOULD** know that the records exist, while no single custodian should have access to the complete recovery material for the highest-risk systems.

III.9 Malware and endpoint protection

III.9.1 Purpose

The purpose of this section is to establish minimum requirements for protecting workstations, laptops, servers, mobile devices, virtual machines, and other endpoints from malware, unauthorized software, exploitation, and other malicious activity.

These requirements are intended to:

- Reduce the likelihood and impact of malware infections
- Protect systems and data from unauthorized access, alteration, destruction, or disclosure
- Ensure that endpoint security controls are deployed, maintained, and monitored
- Establish requirements for software installation, removable media, and endpoint configuration
- Support the timely detection, containment, investigation, and recovery from endpoint security events

III.9.2 Endpoint Inventory

All endpoints owned, operated, managed, or used on behalf of the organization **MUST** be recorded in the asset inventory where reasonably practicable.

The inventory **SHOULD** include:

- Assigned user, system owner, or responsible department
- Device type, hostname, and asset identifier
- Operating system and version
- Physical or logical location
- Security software and protection status
- Encryption status
- Network access or security group
- Support status and expected replacement date
- Last check-in or management status
- Date of the last review

Unknown, unauthorized, or unmanaged endpoints **MUST** be investigated and either approved, secured, isolated, or removed from organizational networks.

III.9.3 Endpoint Security Controls

Endpoints **MUST** use security controls appropriate to their operating system, purpose, risk, and the sensitivity of the information they process.

Where supported and appropriate, endpoints **MUST** use:

- Anti-malware or endpoint detection and response software
- Host-based firewalls
- Secure configuration settings

- Automatic security updates
- Full-disk or volume encryption
- Screen locking and session timeout
- Application control or allowlisting
- Secure boot or equivalent platform protections
- Centralized endpoint management

Security controls **MUST** remain enabled and operational. Users **MUST NOT** disable, bypass, uninstall, or interfere with endpoint security controls unless specifically authorized for an approved administrative or troubleshooting purpose.

Security tools **MUST** be configured to report failures, outdated signatures or detection content, disabled protection, and endpoints that have not checked in within the expected period.

III.9.4 Secure Endpoint Configuration

Endpoints **MUST** be securely configured before being placed into production or issued to a user.

Administrators **MUST**:

- Change or disable default accounts and passwords
- Remove unnecessary software, services, accounts, and components
- Restrict administrative privileges
- Enable supported security features
- Configure automatic screen locking
- Apply approved security and operating system updates
- Configure host-based firewall rules where appropriate
- Restrict access to removable media where required
- Configure logging and monitoring
- Document exceptions to the approved configuration

Endpoints **MUST** use supported operating systems and applications whenever reasonably practicable. Unsupported software **MUST** be removed, upgraded, isolated, or covered by a documented and approved exception.

III.9.5 Malware Protection

Anti-malware and endpoint detection tools **MUST** be configured to scan files, processes, scripts, and other activity appropriate to the operating system and business use.

Protection tools **SHOULD**:

- Receive updates automatically
- Perform scheduled scans
- Perform real-time or on-access scanning where supported

- Detect potentially unwanted applications
- Monitor suspicious process, script, and network activity
- Prevent or quarantine known malicious files
- Report detections and failures to responsible administrators

Administrators **MUST** investigate malware detections according to the severity and potential impact of the event. Malware alerts **MUST NOT** be dismissed without an appropriate review or documented reason.

III.9.6 Software and Application Control

Users **MUST** install and use only approved software. Software obtained from unknown, unauthorized, or untrusted sources **MUST NOT** be installed on organizational endpoints.

Software installation **MUST**:

- Have a documented business or technical purpose
- Use a trusted source
- Be compatible with organizational security requirements
- Be maintained and updated
- Be removed when no longer required

Users **MUST NOT** use unauthorized software, pirated software, software with known unaddressed vulnerabilities, or tools intended to bypass security controls.

Where feasible, standard users **SHOULD** not have local administrator privileges. Administrative privileges **MUST** be granted only when required and **SHOULD** be time-limited.

III.9.7 Removable Media

Removable media **MUST** be used only when necessary and appropriate for the business purpose.

Removable media:

- **MUST** be scanned for malware before use
- **MUST** be encrypted when it contains sensitive or restricted information
- **MUST** be protected from unauthorized access or loss
- **MUST** be obtained from an approved or trusted source
- **MUST** be securely erased or destroyed when no longer required

Unknown removable media **MUST NOT** be connected to organizational endpoints unless it has been approved and scanned.

III.9.8 Email, Web, and File Protection

Email, web browsing, file-sharing, and collaboration systems **SHOULD** use protections against malware, phishing, malicious links, malicious attachments, and unauthorized downloads.

Users **MUST** exercise caution when opening attachments, following links, or executing files received through email, messaging, websites, removable media, or file-sharing services.

Users **MUST** report suspected malware, phishing, unexpected security warnings, or unusual endpoint behavior promptly. Users **MUST NOT** attempt to conceal, delete, or alter evidence of a suspected infection.

III.9.9 Endpoint Isolation and Response

An endpoint suspected of being compromised **MUST** be isolated or disconnected from organizational networks when doing so will not create greater risk or disrupt critical safety-related operations.

Isolation may include:

- Disconnecting wired or wireless network access
- Disabling a user account or session
- Removing the device from a VPN
- Blocking the device through network access controls
- Quarantining malicious files or processes
- Preventing access to sensitive systems

Administrators **MUST** preserve relevant evidence where appropriate and coordinate further action with the incident-response process. Reimaging or wiping an endpoint **SHOULD** not occur until evidence-preservation needs have been considered.

III.9.10 Mobile and Remote Endpoints

Mobile and remote endpoints accessing organizational systems **MUST** use appropriate security controls, including:

- Device authentication
- Automatic screen locking
- Encryption where supported
- Approved operating systems and applications
- Current security updates
- Remote management or remote-wipe capability where appropriate
- Protection against unauthorized access or loss

Lost or stolen endpoints **MUST** be reported promptly. Access associated with a lost or stolen device **MUST** be revoked, disabled, or otherwise protected as appropriate.

III.9.11 Endpoint Review

Endpoint protection status **MUST** be reviewed periodically. The review **SHOULD** verify that:

- Endpoints are present in the asset inventory
- Security tools are installed, enabled, and current
- Operating systems and applications are supported and patched
- Unauthorized software has been removed
- Encryption and screen-lock settings are active where required
- Administrative privileges remain appropriate

- Malware detections and protection failures have been addressed
- Inactive, lost, retired, or unmanaged endpoints have been secured or removed

Endpoints that cannot meet the required protection standards **MUST** be isolated, remediated, replaced, or covered by a documented and approved exception.

III.10 Logging and monitoring

III.10.1 Purpose

The purpose of this section is to establish minimum requirements for collecting, protecting, retaining, reviewing, and responding to logs and monitoring information from systems, applications, network devices, and security controls.

These requirements are intended to:

- Detect unauthorized access, misuse, security incidents, and control failures
- Support investigation, incident response, troubleshooting, and recovery
- Provide accountability for administrative, privileged, and security-sensitive actions
- Ensure that important systems and services generate appropriate logs
- Protect logs from unauthorized access, alteration, deletion, or premature destruction
- Establish appropriate log retention, review, and disposal practices
- Provide timely notification of significant security and operational events
- Support the assessment and improvement of security, availability, and compliance controls

Systems, applications, network devices, and security controls **MUST** generate sufficient logs and monitoring information to support security detection, troubleshooting, incident response, availability management, and compliance requirements.

Logging and monitoring requirements **MUST** be based on the importance of the system, the sensitivity of the information, the likelihood of threats, and applicable legal, contractual, or business requirements.

III.10.2 Logging Requirements

Critical systems and security-relevant services **MUST** produce logs for significant security, administrative, operational, and access events.

Where supported, systems **SHOULD** log:

- Successful and unsuccessful authentication attempts
- Account creation, modification, disabling, and deletion
- Changes to privileges, groups, roles, and access permissions
- Administrative and privileged actions
- Access to sensitive or restricted information
- Security-control changes
- Configuration changes

- Software installation, removal, and updates
- System startup, shutdown, and service failures
- Malware, intrusion, and other security alerts
- Data export, deletion, or transfer events
- Backup, restoration, and recovery events
- Network connections and remote-access sessions

Logging **MUST** be enabled before systems are placed into production unless a documented exception has been approved.

III.10.3 Log Content

Logs **SHOULD** contain enough information to support investigation and correlation. Where applicable, each event **SHOULD** include:

- Date and time
- Source system or device
- User, account, process, or service involved
- Source and destination address or resource
- Event type and outcome
- Affected system, application, account, or data
- Relevant transaction, session, or correlation identifier
- Description of the action or error

Systems **MUST** use synchronized and reasonably accurate time sources. Time synchronization **SHOULD** be centrally managed where practical.

Logs **MUST NOT** contain passwords, private keys, authentication tokens, recovery codes, or other sensitive credential values. Sensitive information that is not required for logging **SHOULD** be masked, removed, or replaced with a non-sensitive identifier.

III.10.4 Centralized Log Collection

Logs from critical systems and security devices **SHOULD** be sent to a centralized logging or security-monitoring system where technically feasible.

Centralized logging **SHOULD** be used to:

- Reduce the risk of log loss or unauthorized alteration
- Correlate events across systems
- Support detection of suspicious activity
- Provide a consistent search and investigation capability
- Alert responsible personnel about important events
- Support incident response and forensic analysis

Log transmission and storage **MUST** be protected against unauthorized access and alteration. Logs transmitted across untrusted networks **SHOULD** use encrypted connections.

Systems **SHOULD** continue producing local logs when centralized collection is unavailable. Collection failures **SHOULD** generate an alert or other notification for responsible personnel.

III.10.5 Log Protection and Access

Access to logs **MUST** be limited to authorized personnel with a business or operational need. Administrative access to logging systems **MUST** use individual accounts where supported and **SHOULD** require MFA.

Log access:

- **MUST** be restricted according to least privilege
- **MUST** be monitored where feasible
- **MUST** not allow ordinary users to alter security logs
- **SHOULD** be separated from the administration of the systems being monitored
- **MUST** be removed when the user's role or responsibilities no longer require it

Logs **MUST** be protected from unauthorized deletion, modification, or premature destruction. Where appropriate, logs **SHOULD** be stored using access controls, integrity protection, write-once storage, or other tamper-resistant mechanisms.

III.10.6 Log Retention

Logs **MUST** be retained for a period appropriate to the system's importance, the sensitivity of the information, investigation requirements, and applicable legal, contractual, or business requirements.

The organization **SHOULD** define retention periods for:

- Authentication and access logs
- Administrative activity logs
- Security alerts
- Network and firewall logs
- Application and database logs
- Backup and restoration logs
- Logs associated with security incidents

Logs associated with an investigation, legal hold, audit, or unresolved incident **MUST** be preserved until the responsible owner authorizes their release or disposal.

Log retention and disposal **MUST** consider the sensitivity of the information contained in the logs. Logs **MUST** be securely deleted or destroyed when the retention period expires, unless they are required for an active investigation or other approved purpose.

III.10.7 Monitoring and Alerting

Security and operational monitoring **MUST** be implemented for systems and services based on their criticality and risk.

Monitoring **SHOULD** identify:

- Repeated authentication failures
- Authentication from unusual locations, devices, or times
- Privilege escalation or unexpected administrative activity
- Creation of unauthorized accounts or access paths
- Changes to security controls or firewall rules
- Malware, intrusion, or suspicious endpoint activity
- Unusual data access, transfer, or deletion
- Unexpected service failures or system shutdowns
- Resource exhaustion or capacity problems
- Backup failures
- Repeated network connection or access-denied events

Alerts **MUST** be assigned an appropriate severity and routed to personnel who are responsible for reviewing and responding to them. Alert thresholds **SHOULD** be adjusted to reduce unnecessary alerts while maintaining the ability to detect significant activity.

High-severity alerts **MUST** be reviewed promptly. Monitoring personnel **MUST** escalate suspected compromise, data loss, or significant control failure according to the incident-response procedure.

III.10.8 Review and Investigation

Logs and alerts **MUST** be reviewed at a frequency appropriate to the system's risk and criticality. Critical security alerts **SHOULD** be reviewed as soon as practicable.

Log reviews **SHOULD** determine whether:

- Suspicious or unauthorized activity occurred
- Administrative actions were expected and approved
- Security controls are operating effectively
- Systems are generating the required logs
- Time synchronization is functioning
- Log collection and storage are operating correctly
- Retention requirements are being met

Investigations **MUST** preserve relevant logs and supporting evidence. Investigators **SHOULD** document the event, affected systems, relevant time period, findings, actions taken, and required follow-up.

III.10.9 Monitoring Privacy and Data Minimization

Monitoring **MUST** be limited to information necessary for security, operational, legal, or business purposes. Access to monitoring information **MUST** be limited to authorized personnel.

Monitoring systems **SHOULD** avoid collecting unnecessary personal information. Where personal information is collected, it **MUST** be protected according to the applicable data-classification and retention requirements.

III.10.10 Availability of Logging Systems

Logging and monitoring systems supporting critical operations **SHOULD** have appropriate backup, capacity, and recovery arrangements. Administrators **MUST** monitor available storage and take action before logs are lost because of capacity limitations.

A failure of centralized logging **MUST** be treated as a control failure and reported to the responsible administrator. The administrator **MUST** restore logging as soon as practicable and determine whether any required events were lost during the failure.

III.10.11 Review of Logging and Monitoring Controls

Logging and monitoring configurations **MUST** be reviewed periodically and after significant changes to systems, applications, networks, threats, or business requirements.

The review **SHOULD** verify that:

- Required systems and devices are generating logs
- Important events are being collected
- Logs contain sufficient information for investigation
- Time synchronization is functioning
- Alerts are routed to responsible personnel
- Log access is appropriately restricted
- Retention periods remain appropriate
- Storage capacity is sufficient
- Monitoring gaps and unresolved alerts are tracked

Systems that cannot meet required logging or monitoring controls **MUST** be documented and approved as an exception. The exception **MUST** identify the missing capability, associated risks, compensating controls, responsible owner, approval, and expiration or review date.

III.11 Backups and restoration

III.11.1 Purpose

Backup and recovery procedures ensure that organizational data, systems, configurations, and recovery information can be restored after accidental deletion, hardware failure, software error, cyberattack, operational error, or other disruptive event.

The purpose of these procedures is to:

- Protect the availability and integrity of organizational data
- Establish consistent backup, retention, monitoring, and recovery requirements
- Reduce the risk of permanent data loss
- Protect backups from unauthorized access, modification, deletion, and ransomware
- Define recovery priorities, Recovery Point Objectives (RPOs), and Recovery Time Objectives (RTOs)
- Ensure that backups can be successfully restored when required

- Support business continuity, incident response, and disaster recovery activities

System owners are responsible for defining the backup and recovery requirements for systems under their control. Administrators are responsible for implementing, monitoring, testing, and documenting backups according to those requirements.

III.11.2 Backup Scope

Backups **MUST** include all data and system components required to resume normal operations. This includes:

- User data
- Databases and application data
- Virtual machines, containers, and configuration files
- Operating system and application configuration
- Firewall, router, switch, and hypervisor configurations
- Identity-server and directory-service data
- Backup system configuration
- Encryption keys and recovery information
- Documentation and recovery procedures

Data **SHOULD** be protected using the 3-2-1-1-0 principle:

- At least 3 copies of the data
- On at least 2 different types of storage
- At least 1 copy stored off-site
- At least 1 copy offline or immutable
- 0 unverified recovery copies

A backup of encrypted data is not sufficient unless the user can also recover the keys required to decrypt it. Encryption keys **MUST** be protected separately from the backup data and their recovery procedure **MUST** be tested.

DO NOT treat RAID, disk mirroring, snapshots, or high availability as a substitute for backups. These technologies may improve availability or protect against certain hardware failures, but they do not reliably protect against accidental deletion, corruption, ransomware, software errors, unauthorized changes, or site-level disasters.

III.11.3 Backup Security

Backup data **MUST** be encrypted both in transit and at rest. Encryption keys **MUST** not be stored only on the system being backed up.

Backup systems **MUST** use separate administrative accounts from production systems. Backup administrators **SHOULD** have only the permissions required to perform their duties, and restore and deletion permissions **SHOULD** be assigned separately where practical.

Backup credentials **MUST** not be reused as domain administrator, server administrator, or ordinary user credentials. Administrative access to backup systems **SHOULD** require MFA and **SHOULD** be logged.

Backup repositories **SHOULD** be isolated from production networks and protected from direct access by ordinary user accounts.

III.11.4 Offline and Immutable Copies

At least one backup copy of critical data **SHOULD** be offline, air-gapped, or protected by an enforced immutability policy.

An immutable backup **MUST** not be capable of being modified, overwritten, or deleted during its retention period, including by ordinary backup administrators. Retention locks and similar controls **SHOULD** be protected by separate administrative credentials.

Cloud synchronization **MUST NOT** be treated as a backup by itself. Synchronization may copy accidental deletions, corrupted files, or ransomware-encrypted files to every synchronized location.

Offline media **MUST** be disconnected from production systems when not being updated. Removable backup media **SHOULD** be stored in a secure, environmentally suitable location and should be encrypted.

III.11.5 Backup Scheduling and Retention

Backups **SHOULD** run automatically according to the importance of the system.

Manual backups may be used as an additional precaution but **MUST NOT** be the only backup method for critical data.

Each system **MUST** have documented recovery requirements. These requirements **MUST** include:

- Recovery Point Objective (RPO): the maximum acceptable amount of data that may be lost after an interruption
- Recovery Time Objective (RTO): the maximum acceptable amount of time required to restore the system or service
- Backup frequency
- Retention period
- Recovery priority

Retention periods **SHOULD** be long enough to recover from delayed discovery of corruption, accidental deletion, or malware. Backup retention **MUST** comply with applicable legal, contractual, and business requirements.

At least one backup copy **SHOULD** use versioning or historical recovery points so that clean data can be recovered from before an incident.

III.11.6 Backup Monitoring

Backup jobs **MUST** generate alerts for failures, missed schedules, expired credentials, insufficient storage, integrity errors, and unexpected changes to retention or deletion settings.

Backup status **SHOULD** be reviewed regularly. A successful backup job does not by itself prove that the backup can be restored.

The user **SHOULD** monitor for:

- Unexpected deletion of backup sets
- Sudden increases in changed or encrypted files
- Disabled backup agents or schedules
- Changes to retention policies
- Unusual administrator logins
- Failed or unauthorized restore attempts

III.11.7 Restore Testing

Restore tests **MUST** be documented and performed at defined intervals.

Testing **SHOULD** include both individual-file restoration and complete system or application restoration.

Critical systems **SHOULD** be tested at least quarterly and after major changes to the backup system, infrastructure, or recovery procedure.

Important files and backup repositories **SHOULD** be sampled more frequently.

A restore test **MUST** verify:

- The backup is available
- The backup is not corrupted
- The required encryption keys are available
- The restored data is complete and usable
- Applications and databases operate correctly
- Required identity, DNS, networking, and authentication services are available
- The actual recovery time meets the defined RTO

Each test **SHOULD** record the date, systems tested, backup version used, result, recovery time, errors found, and corrective actions.

Failed restore tests **MUST** be treated as operational incidents and corrected promptly.

III.11.8 Recovery Procedures

A documented recovery runbook **MUST** identify the order in which systems are restored. The recovery order should normally include:

1. Network connectivity and firewall services
2. Identity, authentication, and DNS services
3. Storage and virtualization infrastructure
4. Databases and core applications
5. File services and user data
6. Non critical systems

Recovery documentation **MUST** be available when production systems, network access, or documentation systems are unavailable. An offline printed copy or separately protected electronic copy **MUST** be maintained.

Recovery procedures **SHOULD** identify authorized personnel, required credentials and keys, backup locations, restoration commands, validation steps, and escalation contacts.

III.12 Network management

III.12.1 Purpose

The purpose of this section is to establish minimum requirements for designing, configuring, operating, securing, monitoring, and maintaining the organization's network infrastructure.

These requirements are intended to:

- Protect network services and systems from unauthorized access
- Support the confidentiality, integrity, and availability of systems and data
- Ensure that network devices and connections are securely configured and maintained
- Limit network access to authorized users, devices, systems, and services
- Reduce the likelihood and impact of network-based security incidents
- Establish requirements for network segmentation, remote access, wireless access, and firewall management
- Ensure that network changes are authorized, documented, tested, and recoverable
- Support reliable operation, troubleshooting, incident response, and service restoration

Network infrastructure **MUST** be managed to protect the confidentiality, integrity, and availability of systems and data. Network devices, services, and connections **MUST** have a documented business purpose, designated owner, and appropriate security configuration.

III.12.2 Network Inventory and Ownership

All network infrastructure **MUST** be recorded in the asset inventory. This includes firewalls, routers, switches, wireless access points, VPN systems, network appliances, virtual networks, cloud networks, and externally accessible services.

The inventory **SHOULD** include:

- Device or service name
- Device type and physical or logical location
- Manufacturer, model, and serial number, where applicable
- IP addresses, hostnames, and network segments
- System or service owner
- Technical administrator
- Business purpose
- Internet exposure and external dependencies
- Firmware or operating system version
- Support status and expected replacement date
- Date of the last review

Each significant network segment, connection, firewall, and externally accessible service **MUST** have a designated owner.

III.12.3 Network Architecture and Segmentation

Networks **MUST** be designed and configured according to business and security requirements. Systems with different levels of trust or sensitivity **SHOULD** be separated using appropriate controls such as VLANs, routing rules, firewalls, security groups, or separate physical networks.

Where technically and operationally appropriate:

- User workstations **SHOULD** be separated from server and infrastructure networks
- Guest and personal devices **MUST** be isolated from internal business systems
- Management interfaces **MUST** be restricted to authorized administrators
- Internet-facing systems **MUST** be separated from internal networks
- Backup networks and storage **SHOULD** be protected from unauthorized access and routine user traffic
- Development, testing, and production environments **SHOULD** be separated
- Systems handling sensitive information **SHOULD** be placed in appropriately protected network segments

Network access **MUST** be denied by default unless it is explicitly required and authorized. Firewall and access-control rules **MUST** specify the source, destination, service, purpose, and owner.

III.12.4 Firewalls and Access Controls

Firewalls, routers, wireless systems, VPNs, and other network security devices **MUST** use secure configurations.

Network access rules:

- **MUST** be limited to the minimum required protocols, ports, addresses, and users
- **MUST** have a documented business or technical purpose
- **MUST** be reviewed periodically
- **MUST** be removed when no longer required
- **MUST** be tested after significant changes
- **SHOULD** include an expiration date for temporary access

Broad rules that allow unrestricted access between networks **SHOULD** be avoided. Rules that permit access from the Internet to internal systems **MUST** be specifically approved and protected with appropriate authentication and monitoring.

Administrative access to network devices **MUST** use individual administrator accounts where supported. Shared administrative accounts **SHOULD** be avoided and, when required, **MUST** be documented and controlled.

III.12.5 Wireless Networks

Wireless networks **MUST** use security settings appropriate to the capabilities of the devices and the sensitivity of the information being transmitted.

Wireless networks:

- **MUST** use strong encryption and authentication
- **MUST** use separate networks for guests and internal users where guest access is provided
- **MUST** restrict administrative access to authorized personnel
- **MUST** use a unique administrative password or other appropriate administrative authentication
- **SHOULD** use enterprise authentication where supported

- **MUST NOT** use default administrator passwords or default security settings

Guest wireless access **MUST** not provide access to internal systems unless the access has been specifically authorized and secured.

III.12.6 Remote Access and VPN

Remote access to internal systems **MUST** be authorized, encrypted, and limited to the systems and services required for the approved purpose.

Remote access systems **MUST**:

- Require individual user accounts
- Use MFA where supported
- Use approved encryption protocols
- Enforce access restrictions based on user, device, network, or other appropriate conditions
- Log successful and unsuccessful authentication attempts
- Remove or disable access when it is no longer required

Remote administrative access **MUST** be restricted to authorized administrators and **SHOULD** be limited to approved devices and managed network connections. Remote access tools that bypass organizational security controls **MUST NOT** be installed or used without approval.

Third-party remote access **MUST** be limited to the required systems, time period, and permissions. Temporary access **SHOULD** expire automatically whenever technically possible.

III.12.7 Network Device Configuration

Network devices **MUST** be securely configured before being placed into production.

Administrators **MUST**:

- Change default passwords and disable unused default accounts
- Disable unnecessary services, interfaces, and protocols
- Apply approved firmware and security updates
- Use secure management protocols
- Restrict management access to authorized networks or administrator devices
- Synchronize device time with an approved time source
- Save and protect current configurations
- Document significant configuration changes
- Back up configurations when needed for recovery

Insecure protocols such as unencrypted administrative services **MUST NOT** be used where a secure alternative is available. Network configuration backups **MUST** be protected from unauthorized access because they may contain credentials, keys, addresses, or other sensitive information.

III.12.8 Network Changes

Changes to network infrastructure, firewall rules, routing, wireless configuration, VPN settings, or network security controls **MUST** follow the approved change-management process.

A significant network change **MUST** include:

- A description and business purpose
- The affected systems and services
- Security and availability considerations
- Implementation steps
- Testing or validation steps
- A rollback or recovery plan
- The responsible administrator
- Required approval
- The date of implementation

Emergency network changes may be implemented when necessary to protect systems or restore service, but they **MUST** be documented and reviewed afterward.

III.12.9 Network Availability and Capacity

Network infrastructure **MUST** be monitored and maintained to support required business operations.

Administrators **SHOULD** monitor:

- Availability and service interruptions
- Bandwidth and utilization
- Capacity and performance
- Hardware and interface errors
- Unusual traffic patterns
- VPN and wireless authentication failures
- Firewall and intrusion-prevention alerts
- Expiring certificates and service credentials

Critical network components **SHOULD** have appropriate redundancy, documented recovery procedures, and tested restoration procedures based on their business importance.

III.12.10 Network Security Monitoring

Network devices and services **MUST** generate security and operational logs appropriate to their function. Relevant logs **SHOULD** be forwarded to a centralized logging system where technically and operationally feasible.

Network logs **SHOULD** include:

- Administrative logins and configuration changes

- Firewall rule changes
- VPN connections and disconnections
- Authentication failures
- Blocked and permitted security events
- Significant routing or interface changes
- Wireless access and authentication events
- Malware, intrusion, or denial-of-service alerts

Network logs **MUST NOT** contain passwords, private keys, recovery secrets, or other sensitive credential values.

III.12.11 Network Review

Network infrastructure and access rules **MUST** be reviewed periodically and after significant organizational, technical, or security changes.

The review **SHOULD** verify that:

- Network devices and connections are accurately inventoried
- Owners and administrators are assigned
- Firewall and access-control rules remain necessary
- Unused services, ports, accounts, and connections have been removed
- Remote access remains authorized
- Wireless networks remain appropriately secured
- Firmware and software remain supported
- Network diagrams and documentation are current
- Security and availability issues have been assigned for remediation

Any network component that cannot be securely maintained **MUST** be isolated, replaced, or formally approved as an exception.

III.13 Change management

III.13.1 Purpose

Change-management procedures ensure that changes to systems, applications, networks, devices, configurations, data, and technology services are authorized, evaluated, tested, implemented, and documented in a controlled manner.

The purpose of change management is to reduce service interruptions, security weaknesses, data loss, configuration errors, and unintended effects on other systems.

III.13.2 Change Requirements

Changes **MUST** be managed when they may affect:

- System security or access controls
- System availability or performance
- Network connectivity or routing
- Applications, databases, or stored data
- Operating systems, firmware, or installed software
- Backup, logging, monitoring, or recovery capabilities
- Encryption, authentication, or authorization
- Compliance, contractual, or legal requirements

Changes may include installations, upgrades, patches, configuration changes, migrations, integrations, removals, and changes to service providers.

Routine administrative tasks that do not materially affect security, availability, performance, or functionality may follow an approved standard-change procedure.

III.13.3 Change Classification

Changes **SHOULD** be classified according to their risk, urgency, complexity, and expected effect.

Change classifications may include:

- **Standard change:** A low-risk, repeatable change with an approved procedure.
- **Normal change:** A planned change that requires review and approval before implementation.
- **Emergency change:** An urgent change required to address an active incident, critical vulnerability, service outage, or immediate operational risk.

The person implementing a change **MUST** use the appropriate process for the change classification.

A change **MUST** not be classified as standard merely to avoid review or approval requirements.

III.13.4 Change Requests

Normal changes **MUST** be documented before implementation.

A change request **MUST** include:

- A description of the proposed change
- The reason and business purpose
- The affected systems, services, data, and users
- The expected security, availability, and operational effects
- The risks associated with the change
- The implementation steps
- The testing and validation plan

- The planned implementation date and maintenance window
- The rollback or recovery procedure
- The person responsible for implementation
- The required approvers

Changes **MUST** be approved by an authorized person before implementation unless the emergency-change process applies.

III.13.5 Change Assessment

The change requester and system owner **MUST** evaluate the potential effects of a proposed change.

The assessment **SHOULD** consider:

- Confidentiality, integrity, and availability
- Dependencies between systems and services
- Effects on users and business operations
- Security controls and monitoring
- Backup and recovery requirements
- Compatibility with existing hardware and software
- Data-protection and compliance requirements
- Required downtime or service interruption
- Risk of failure and the ability to reverse the change

High-risk changes **SHOULD** receive additional technical review and management approval.

Changes affecting critical systems **SHOULD** be scheduled during an approved maintenance window whenever reasonably practicable.

III.13.6 Testing

Changes **SHOULD** be tested before production implementation.

Testing **SHOULD** be performed in a development, test, staging, or other environment that is separate from production when reasonably practicable.

Testing **SHOULD** verify:

- The change performs its intended function
- Existing functionality remains available
- Security controls remain effective
- Data is not corrupted or lost
- Monitoring and logging continue to operate
- Backup and recovery procedures remain usable
- Dependent systems continue to function

Test results **MUST** be documented for significant or high-risk changes.

Testing may be limited or skipped for an emergency change when delay would create greater risk. The reason **MUST** be documented.

III.13.7 Implementation

Changes **MUST** be implemented according to the approved change plan.

The person implementing the change **MUST** verify that:

- The correct system and environment are being changed
- A current backup or recovery point is available when appropriate
- Required personnel are available
- Required approvals have been obtained
- The approved implementation steps are followed
- The implementation is documented

Unplanned changes made during implementation **MUST** be documented and reviewed.

Changes **MUST** not be implemented using unauthorized accounts, unapproved software, or undocumented procedures.

III.13.8 Rollback and Recovery

Each significant change **MUST** have a documented rollback or recovery procedure.

The rollback procedure **SHOULD** identify:

- Conditions that require rollback
- The person authorized to initiate rollback
- The steps required to restore the previous state
- Required backups or recovery points
- Expected service interruption
- Validation steps after rollback
- Communication requirements

If a change fails, causes an unacceptable security or operational issue, or cannot be validated, the change **SHOULD** be rolled back when reasonably practicable.

III.13.9 Post-Implementation Review

Significant changes **MUST** be reviewed after implementation.

The post-implementation review **SHOULD** confirm:

- The change achieved its intended purpose
- Systems and services are operating correctly
- Security controls remain effective
- Monitoring and logging are functioning
- No unauthorized changes were introduced
- Required documentation has been updated

- Any incidents or unexpected effects were addressed

Failed, partially completed, and emergency changes **MUST** receive a post-implementation review.

The change record **MUST** be updated with the implementation result, validation results, problems encountered, rollback actions, and final status.

III.13.10 Emergency Changes

Emergency changes may be implemented without normal advance approval when necessary to:

- Contain or respond to a security incident
- Address an actively exploited vulnerability
- Restore a critical service
- Prevent immediate data loss
- Prevent significant harm to systems, users, or operations

Emergency changes **MUST** be authorized by the responsible manager, system owner, incident leader, or other designated authority whenever reasonably practicable.

Emergency changes **MUST** be documented as soon as possible and reviewed after implementation.

III.13.11 Separation of Duties

Where reasonably practicable, the person requesting a high-risk change **SHOULD** not be the only person approving and implementing that change.

Changes affecting privileged access, security controls, financial systems, sensitive data, or critical services **SHOULD** receive independent review.

No person **SHOULD** approve their own high-risk change without additional review or documented justification.

III.13.12 Change Records

Change records **MUST** be retained according to the organization's record-retention requirements.

Change records **SHOULD** include:

- Change identification number
- Request date
- Requester and responsible implementer
- Affected systems and services
- Change classification
- Risk assessment
- Approval records
- Planned and actual implementation dates
- Testing results
- Rollback or recovery information

- Implementation outcome
- Post-implementation review

System documentation, configuration baselines, network diagrams, operating procedures, and recovery documentation **MUST** be updated after significant changes.

III.13.13 Unauthorized Changes

Unauthorized changes **MUST** be investigated and documented.

The investigation **SHOULD** determine:

- What was changed
- When the change occurred
- Who or what performed the change
- Why the change occurred
- Whether security or availability was affected
- Whether rollback or remediation is required
- Whether additional controls are needed

Unauthorized changes that may indicate compromise, misuse, or loss of control **MUST** be reported according to the incident-response procedures.

III.14 Incident response

III.14.1 Purpose

The purpose of this section is to establish minimum requirements for preparing for, identifying, reporting, assessing, containing, investigating, recovering from, and learning from security and technology incidents.

These requirements are intended to:

- Reduce the impact and duration of security and operational incidents
- Ensure that suspected incidents are reported and handled consistently
- Establish clear responsibilities and communication requirements
- Protect systems, data, users, and organizational operations
- Preserve relevant evidence for investigation and follow-up
- Support timely recovery and restoration of affected services
- Identify corrective actions that reduce the likelihood of recurrence

III.14.2 Incident Definition

An incident is an actual or suspected event that may negatively affect the confidentiality, integrity, or availability of systems, services, accounts, networks, or data.

Incidents may include:

- Unauthorized access or attempted unauthorized access
- Malware, ransomware, or suspected system compromise
- Phishing, credential theft, or account takeover
- Loss or unauthorized disclosure of sensitive information
- Lost or stolen devices
- Accidental deletion, alteration, or destruction of data
- Denial-of-service or significant service interruption
- Unauthorized changes to systems, applications, or network controls
- Backup failure affecting recovery capability
- Physical damage or environmental conditions affecting critical systems
- Violations of security procedures or approved configurations

Personnel **MUST** report suspected incidents even when the facts are incomplete or the impact is not yet known.

III.14.3 Incident Response Responsibilities

Management **MUST** designate a person or team responsible for coordinating incident response. The incident-response function **SHOULD** include, where appropriate:

- Incident coordinator
- System and network administrators
- System and data owners
- Management representatives
- Legal, compliance, or privacy representatives
- Communications or public-relations representatives
- Human resources representatives
- Relevant vendors, insurers, or external specialists

Incident-response responsibilities **MUST** be assigned before an incident occurs. Contact information **MUST** be maintained and reviewed periodically.

Personnel involved in incident response **SHOULD** receive appropriate training and participate in exercises or testing.

III.14.4 Incident Reporting

Users and administrators **MUST** report suspected incidents promptly to management, the designated security contact, or another approved reporting channel.

Incident reports **SHOULD** include:

- Date and time of discovery
- Person reporting the event

- Affected user, device, account, system, service, or data
- Description of the observed activity
- Actions already taken
- Available logs, messages, screenshots, or other evidence
- Known or suspected impact

Personnel **MUST** not delay reporting while attempting to determine the complete cause or scope of an event.

Incident reports and response communications **MUST** be handled according to their sensitivity. Information about an active incident **MUST** be shared only with personnel who have a business or response-related need to know.

III.14.5 Incident Classification

Incidents **MUST** be classified according to their severity, scope, affected resources, data involved, operational impact, and potential legal or contractual consequences.

Classification **SHOULD** consider:

- Number and importance of affected systems
- Type and sensitivity of affected information
- Whether unauthorized access is confirmed or suspected
- Availability and operational impact
- Duration and current status of the event
- Likelihood of continued or repeated activity
- Potential regulatory, contractual, legal, or safety impact

The incident coordinator **MUST** assign or confirm the severity level and **MUST** escalate the incident when new information indicates greater impact or risk.

III.14.6 Incident Response Process

Incident response **MUST** follow a documented process that includes:

1. Preparation
2. Identification and reporting
3. Initial assessment and classification
4. Containment
5. Evidence preservation and investigation
6. Eradication
7. Recovery and service restoration
8. Post-incident review and corrective action

The order and extent of response activities may vary according to the incident. Actions **MUST** be coordinated to avoid increasing the damage, destroying evidence, or disrupting critical operations unnecessarily.

III.14.7 Containment

The incident-response team **MUST** take reasonable steps to contain an incident and prevent additional harm.

Containment actions may include:

- Isolating affected devices or network segments
- Disabling compromised accounts
- Revoking sessions, tokens, keys, or credentials
- Blocking malicious addresses, domains, files, or processes
- Removing unauthorized access
- Suspending affected services
- Restricting access to affected systems or data
- Activating alternate systems or recovery procedures

Containment actions **MUST** consider business continuity, safety, evidence preservation, and the possibility that the attacker or malware remains active.

Compromised credentials **MUST** be changed or revoked. Replacement credentials **MUST** be generated and distributed securely.

III.14.8 Evidence Preservation and Investigation

Relevant evidence **MUST** be preserved when an incident may require investigation, legal action, regulatory reporting, insurance notification, or other formal review.

Evidence may include:

- System, application, network, authentication, and security logs
- Disk, memory, or system images where appropriate
- Malware samples or suspicious files
- Email messages, headers, links, and attachments
- Screenshots and error messages
- Access records and account activity
- Configuration files and change records
- Relevant physical security or access records

Evidence **MUST** be protected from alteration or unauthorized access. Investigators **SHOULD** document when evidence was collected, by whom, from which source, and how it was stored or transferred.

Administrators **MUST NOT** alter or delete relevant logs, files, accounts, or systems without considering evidence-preservation requirements and coordinating with the incident coordinator.

III.14.9 Eradication and Recovery

After containment and investigation, the response team **MUST** remove the cause of the incident and address known weaknesses before returning affected systems to normal operation.

Eradication and recovery activities may include:

- Removing malware or unauthorized software
- Rebuilding or restoring compromised systems
- Applying security patches and configuration changes
- Resetting affected passwords and authentication factors
- Removing unauthorized accounts, rules, services, or access paths
- Restoring data from verified backups
- Testing restored systems before returning them to production
- Increasing monitoring for signs of continued compromise

Systems **MUST** be validated before being returned to normal use. Validation **SHOULD** confirm that the system is secure, functional, appropriately monitored, and connected only to authorized services.

Recovery activities **MUST** be coordinated with system owners and business stakeholders. Critical services **SHOULD** be restored according to documented recovery priorities.

III.14.10 Communication and Notification

Incident communications **MUST** be coordinated by authorized personnel. Personnel **MUST NOT** make public statements, contact affected external parties, or notify authorities unless authorized to do so.

Management **MUST** determine whether an incident requires notification to:

- Affected individuals
- Customers or business partners
- Vendors or service providers
- Insurers
- Regulators or government authorities
- Law enforcement

Required notifications **MUST** be made within applicable time limits and using approved communication methods. Incident communications **SHOULD** be accurate, limited to confirmed information, and updated when significant facts change.

III.14.11 Post-Incident Review

A post-incident review **MUST** be performed for significant incidents and **SHOULD** be performed for recurring or high-risk events.

The review **SHOULD** identify:

- What happened and when
- Systems, accounts, data, and services affected

- How the incident was detected
- Actions that were successful or unsuccessful
- Root or contributing causes
- Control failures or process weaknesses
- Required corrective actions
- Responsible owners and target completion dates
- Changes needed to policies, procedures, training, or technology

Corrective actions **MUST** be tracked until completed or formally accepted as a risk. Lessons learned **SHOULD** be incorporated into security controls, incident procedures, training, and recovery plans.

III.14.12 Incident Records

An incident record **MUST** be maintained for each reported incident. The record **SHOULD** include:

- Incident identifier
- Date and time reported
- Reporter and incident coordinator
- Classification and severity
- Affected systems, accounts, services, and data
- Timeline of significant events and response actions
- Evidence collected and its storage location
- Notifications and communications
- Recovery actions
- Post-incident findings
- Corrective actions and completion status
- Date the incident was closed

Incident records **MUST** be protected from unauthorized access and retained according to applicable legal, contractual, business, and records-management requirements.

III.14.13 Testing and Maintenance

The incident-response process **MUST** be reviewed periodically and after significant incidents, organizational changes, or changes to critical systems.

Incident-response procedures **SHOULD** be tested through exercises, walkthroughs, simulations, or technical testing. Testing **SHOULD** include relevant personnel, systems, communication methods, escalation paths, backups, and recovery procedures.

Identified weaknesses **MUST** be documented and assigned for correction. Contact lists, response procedures, system inventories, recovery information, and escalation instructions **MUST** be kept current.

III.15 Physical security

III.15.1 Purpose

This section defines requirements for protecting facilities, equipment, systems, media, and information from unauthorized physical access, theft, damage, tampering, environmental hazards, and service interruption.

III.15.2 Scope

These requirements apply to all organizational offices, work areas, server rooms, equipment rooms, storage areas, backup locations, and other facilities where organizational systems or information are located.

They also apply to organizational equipment used at homes, remote offices, customer locations, public locations, or other facilities.

III.15.3 Physical Access

Physical access to areas containing systems or sensitive information **MUST** be limited to authorized individuals.

Access controls **SHOULD** include appropriate measures such as:

- Keys, access cards, badges, or electronic locks
- Visitor sign-in and escort procedures
- Physical barriers and locked cabinets
- Security cameras or alarm systems where appropriate
- Access logs or other records of entry

Access rights **MUST** be granted according to job responsibilities and business need.

Physical access **MUST** be removed promptly when a person leaves the organization, changes roles, or no longer requires access.

Keys, access cards, badges, and other physical access devices **MUST** be returned, disabled, or replaced when they are lost, stolen, or no longer required.

III.15.4 Visitors and Contractors

Visitors and contractors **MUST** be authorized before entering restricted areas.

Visitors **MUST**:

- Sign in when required
- Wear visitor identification when appropriate
- Remain accompanied or monitored in restricted areas
- Access only the areas necessary for their approved purpose
- Return temporary access devices before leaving

Visitors and contractors **MUST NOT** be left unsupervised in areas containing sensitive systems or information unless their access has been specifically approved.

III.15.5 Restricted Areas

Server rooms, network equipment rooms, backup storage areas, and other restricted locations **MUST** be secured against unauthorized access.

Restricted areas **MUST**:

- Remain locked when unattended
- Be protected from unauthorized equipment removal
- Be kept free of unnecessary combustible materials
- Have access limited to authorized personnel
- Be monitored for environmental or equipment risks where appropriate

Equipment, cables, network ports, and storage media in restricted areas **MUST** be protected against tampering or unauthorized connection.

III.15.6 Equipment Protection

Organizational equipment **MUST** be protected against theft, unauthorized use, damage, and environmental hazards.

Workstations and laptops containing organizational information **SHOULD** be secured using appropriate physical measures, including:

- Locking devices or secure storage
- Screen locks
- Cable locks where appropriate
- Secure transportation
- Protection from unauthorized viewing

Devices **MUST** not be left unattended in vehicles or other locations where theft or unauthorized access is reasonably likely.

Equipment used in public or shared locations **MUST** be positioned to prevent unauthorized viewing or access whenever practical.

III.15.7 Clear Desk and Clear Screen

Users **SHOULD** keep desks and work areas clear of Confidential and Restricted information when the information is not actively being used.

Confidential and Restricted documents **MUST** be stored in locked cabinets, secure rooms, or other approved locations when unattended.

Users **MUST** lock their screens when leaving devices unattended.

Printed sensitive information **MUST NOT** be left in printers, meeting rooms, reception areas, or other publicly accessible locations.

III.15.8 Environmental Protection

Critical systems and equipment **MUST** be protected from environmental conditions that could cause loss, damage, or interruption.

Where appropriate, facilities **SHOULD** provide protection against:

- Fire, smoke, and water
- Excessive heat or humidity
- Power interruption or electrical damage
- Unauthorized removal
- Dust and other contaminants
- Natural disasters and other facility hazards

Critical equipment **SHOULD** use appropriate power protection, such as surge protection, backup power, or an uninterruptible power supply.

Environmental alarms and facility failures **MUST** be reported and investigated promptly when they could affect systems or information.

III.15.9 Removable Media

Removable media **MUST** be approved before it is connected to organizational systems when the media is not organization-owned or trusted.

Removable media containing Confidential or Restricted information **MUST** be encrypted when technically feasible.

Removable media **MUST** be stored securely when not in use and **MUST** be securely disposed of when no longer required.

Unknown or suspicious removable media **MUST NOT** be connected to organizational systems.

III.15.10 Remote and Home Work Areas

Personnel working remotely **MUST** take reasonable steps to prevent unauthorized access, disclosure, theft, or damage.

Remote work areas **SHOULD**:

- Prevent unauthorized people from viewing screens or documents
- Keep organizational devices physically secure
- Use private and trusted workspaces when handling sensitive information
- Prevent family members, guests, or other unauthorized individuals from using organizational devices
- Secure paper records and removable media

Organizational equipment **MUST** be transported and stored in a manner that reduces the risk of loss, theft, or damage.

III.15.11 Equipment Removal and Disposal

Equipment **MUST** be authorized before it is removed from organizational facilities.

Before equipment is transferred, returned, recycled, or disposed of, storage media **MUST** be securely erased or physically destroyed according to the data classification and disposal requirements.

Physical access devices, labels, documents, storage media, and other items containing organizational information **MUST** be returned or securely destroyed when no longer required.

III.15.12 Physical Security Incidents

Lost keys, badges, devices, media, documents, or other physical assets **MUST** be reported promptly.

Suspected unauthorized entry, theft, tampering, environmental damage, or physical security control failure **MUST** be reported according to the incident response procedures.

The organization **SHOULD** document investigations and corrective actions for significant physical security incidents.

III.15.13 Review

Physical security controls **SHOULD** be reviewed at least annually and whenever facilities, equipment, personnel, system requirements, or threats change.

Access lists for restricted areas **MUST** be reviewed periodically to verify that access remains appropriate.

III.16 System decommissioning

III.16.1 Purpose

This section defines requirements for securely retiring, replacing, transferring, or removing systems, applications, accounts, equipment, services, and information.

The purpose is to prevent unauthorized access, data exposure, service disruption, loss of records, and unmanaged dependencies when a system or service is no longer required.

III.16.2 Scope

These requirements apply to:

- Servers, workstations, laptops, mobile devices, and network equipment
- Virtual machines, containers, cloud resources, and storage volumes
- Applications, databases, websites, and hosted services
- User, administrator, service, vendor, and emergency accounts
- Encryption keys, certificates, API keys, tokens, and credentials
- Backups, logs, documentation, and other associated records

III.16.3 Decommissioning Authorization

A system or service **MUST** have an approved decommissioning plan before it is retired or removed.

The plan **MUST** identify:

- The system, service, device, or account being decommissioned
- The business and technical owner
- The reason for decommissioning
- The planned date and responsible personnel
- Dependencies and connected systems
- Information and records that must be retained

- Backup and recovery considerations
- Data sanitization and disposal methods
- Required notifications and approvals

Critical systems **MUST** not be decommissioned without approval from the system owner and the appropriate management or technical authority.

III.16.4 Dependency Review

Before decommissioning, the responsible administrator **MUST** identify systems, applications, integrations, users, vendors, network connections, scheduled tasks, certificates, credentials, backups, and other dependencies.

The dependency review **SHOULD** include:

- Applications and services that rely on the system
- Network routes, firewall rules, and integrations
- Data feeds and automated processes
- Monitoring and alerting configurations
- Backup and replication jobs
- DNS records and certificates
- Service accounts and stored credentials
- Documentation and support procedures

Dependencies **MUST** be migrated, disabled, or formally accepted before final removal.

III.16.5 Data Retention and Transfer

Information stored on a system **MUST** be reviewed before decommissioning.

The system owner **MUST** determine whether information should be:

- Transferred to a replacement system
- Archived according to retention requirements
- Included in an approved backup
- Securely deleted
- Returned to a customer, vendor, or other authorized party

Data **MUST** not be retained longer than required unless a documented business, legal, contractual, or regulatory reason exists.

Archived information **MUST** remain subject to access control, classification, encryption, retention, monitoring, and disposal requirements.

III.16.6 Account and Credential Removal

Accounts associated with a decommissioned system **MUST** be disabled or removed when they are no longer required.

This includes:

- User accounts
- Administrator accounts
- Service accounts
- Vendor accounts
- Emergency accounts
- API keys and access tokens
- SSH keys and certificates
- Stored passwords and connection credentials

Credentials that may have been exposed during the system's lifecycle **SHOULD** be rotated or revoked.

Network access rules, firewall exceptions, VPN access, remote-management settings, and other access paths **MUST** be removed when no longer required.

III.16.7 Data Sanitization

Storage media **MUST** be sanitized before equipment is reused, transferred, returned, sold, recycled, or disposed of.

Sanitization methods **MUST** be appropriate to the sensitivity of the information and the type of media. Acceptable methods may include:

- Approved secure erasure
- Cryptographic erasure
- Factory reset combined with secure deletion where appropriate
- Physical destruction
- Destruction by an approved disposal provider

Ordinary file deletion or reformatting **MUST NOT** be considered sufficient for Confidential or Restricted information unless the approved sanitization process verifies that the information cannot reasonably be recovered.

III.16.8 Hardware and Media Disposal

Hardware and removable media **MUST** be tracked through disposal or transfer.

The disposal record **SHOULD** include:

- Asset identifier
- Equipment description
- Assigned owner or department

- Date of disposal or transfer
- Sanitization method
- Person or provider performing the work
- Final disposition

Third-party disposal providers **MUST** be approved and **SHOULD** provide evidence of secure disposal when required by the data classification or contract.

III.16.9 Service and Cloud Decommissioning

Cloud resources and hosted services **MUST** be reviewed before cancellation or deletion.

The review **MUST** address:

- Data stored by the provider
- Snapshots, replicas, and backup copies
- Connected accounts and integrations
- Domains, certificates, and DNS records
- Billing and subscription ownership
- Audit logs and records required for retention
- Provider-specific deletion and recovery procedures

Cloud resources **MUST** be deleted or disabled after required data, records, and dependencies have been handled.

III.16.10 Verification

After decommissioning, the responsible administrator **MUST** verify that:

- The system is no longer accessible through approved or known access paths
- Required data has been transferred or archived
- Unneeded data has been securely removed
- Accounts, credentials, keys, and certificates have been disabled or revoked
- Monitoring and backup jobs have been updated
- Network rules and integrations have been removed
- Asset and system inventories are current
- Documentation reflects the final state

Critical system decommissioning **SHOULD** include a second-person review or formal approval of the completion evidence.

III.16.11 Emergency Decommissioning

A system may be isolated or decommissioned without following the normal schedule when necessary to address an active compromise, unacceptable risk, safety issue, legal requirement, or serious operational threat.

Emergency actions **MUST** be documented after the immediate risk has been controlled.

The documentation **MUST** include the reason for the emergency action, approvals or notifications, data-handling decisions, and follow-up activities.

III.16.12 Records

Decommissioning records **MUST** be retained according to applicable business, legal, contractual, and records-management requirements.

The organization **SHOULD** retain evidence of approvals, data transfers, sanitization, disposal, verification, and final inventory updates for critical systems and sensitive information.

III.16.13 Review

Decommissioning procedures **SHOULD** be reviewed at least annually and whenever there is a significant change to technology, service providers, retention requirements, or organizational processes.

III.17 Review, testing, and exceptions

III.17.1 Purpose

This section defines requirements for reviewing, testing, measuring, and improving the organization's security and technology controls. It also defines the process for documenting, approving, monitoring, and closing exceptions to these procedures.

The purpose is to ensure that controls remain effective, risks are understood, deficiencies are addressed, and deviations are formally managed.

III.17.2 Scope

These requirements apply to all systems, applications, infrastructure, processes, personnel, vendors, and controls covered by these procedures.

They apply to:

- Security and access-control reviews
- Configuration and vulnerability assessments
- Backup and recovery testing
- Incident response exercises
- Business continuity and disaster recovery testing
- Physical security reviews
- Vendor and cloud control reviews
- Internal audits and compliance assessments
- Exceptions and compensating controls

III.17.3 Periodic Review

These procedures **MUST** be reviewed at least annually and whenever there is a significant change to:

- Systems, applications, or infrastructure
- Business operations or organizational structure
- Personnel or assigned responsibilities
- Legal, regulatory, or contractual requirements
- Threats, vulnerabilities, or business risks
- Technology vendors or hosted services

Reviews **MUST** determine whether the procedures remain appropriate, effective, current, and consistent with the organization's risks and responsibilities.

III.17.4 Control Testing

Security and technology controls **SHOULD** be tested at a frequency appropriate to their importance and risk.

Testing may include:

- Access reviews
- Configuration reviews
- Vulnerability scanning
- Patch verification
- Backup restoration tests
- Log and monitoring reviews
- Phishing or security-awareness exercises
- Incident response exercises
- Disaster recovery exercises
- Physical access reviews
- Vendor and service-provider assessments

Critical controls **MUST** be tested at least annually unless a documented risk assessment supports a different frequency.

Testing **MUST** be performed by a person or team with sufficient independence and competence. Individuals **SHOULD** not approve the effectiveness of controls that they exclusively operate when independent review is reasonably practicable.

III.17.5 Test Planning

Each significant test **SHOULD** have a documented plan that identifies:

- The purpose and scope of the test
- Systems, processes, or controls being tested

- Test methods and success criteria
- Responsible personnel
- Planned date and duration
- Potential operational impact
- Required approvals and notifications
- Evidence that will be collected

Testing **MUST** be planned to minimize unnecessary disruption and mustnot create unacceptable risk to production systems or sensitive information.

III.17.6 Results and Corrective Actions

Test results **MUST** be documented and communicated to the responsible owner.

Each identified deficiency **SHOULD** include:

- Description of the finding
- Affected system, process, or control
- Risk and potential impact
- Severity or priority
- Recommended corrective action
- Responsible owner
- Target completion date
- Current status

High-risk findings **MUST** be addressed promptly or managed through an approved exception.

Corrective actions **MUST** be tracked until completion, formal acceptance, or replacement by an effective alternative control.

III.17.7 Exception Requirements

A requirement may be excepted only when compliance is not currently possible, would create a greater operational risk, or is not appropriate for the specific system or circumstance.

Exceptions **MUST** be documented before or, in an emergency, as soon as reasonably possible after the deviation occurs.

Each exception record **MUST** identify:

- The requirement being excepted
- The affected system, process, or information
- The reason compliance is not possible or appropriate
- The risks created by the exception
- Compensating controls
- The responsible system or business owner

- The approving authority
- The date approved
- The expiration or review date
- Required corrective actions

Exceptions **MUST** be limited to the smallest practical scope and shortest practical duration.

An exception **MUST NOT** be used as a permanent substitute for implementing a reasonable security control unless the risk is formally accepted and periodically reviewed.

III.17.8 Exception Approval

Exceptions must be approved by an authority with sufficient responsibility for the affected risk.

High-risk exceptions **MUST** be approved by management or another designated risk authority.

A person **MUST NOT** approve their own exception when the exception affects systems, access, or controls for which they are directly responsible, unless no reasonable separation of duties exists and the approval is independently reviewed.

III.17.9 Compensating Controls

Compensating controls **MUST** reduce the risk created by the exception and **MUST** be appropriate to the sensitivity, criticality, and exposure of the affected system or information.

Examples may include:

- Additional monitoring
- Network isolation
- Restricted administrative access
- Increased review frequency
- Temporary manual procedures
- Additional backups
- Enhanced logging
- Additional approval requirements

Compensating controls **MUST** be documented, assigned to an owner, and tested to confirm that they are operating as intended.

III.17.10 Exception Review and Closure

Open exceptions **MUST** be reviewed at least annually and more frequently when the risk is high or the exception is temporary.

An exception **MUST** be closed when:

- The original requirement has been implemented
- The affected system has been replaced or retired
- The risk no longer exists

- The exception has expired and is not renewed
- The responsible authority withdraws approval

Closed exceptions **SHOULD** include evidence of the final action and the date of closure.

Expired exceptions **MUST NOT** remain active without renewed approval.

III.17.11 Evidence and Records

Evidence of reviews and tests **MUST** be retained according to applicable records-management requirements.

Evidence may include:

- Test plans and results
- Approval records
- Access review reports
- Vulnerability and configuration reports
- Backup restoration records
- Incident and recovery exercise records
- Corrective-action tracking
- Exception records

Evidence containing sensitive information **MUST** be protected according to its information classification.

III.17.12 Reporting

Management **SHOULD** receive periodic reports regarding:

- Significant control deficiencies
- Overdue corrective actions
- Open high-risk exceptions
- Testing completion and results
- Repeated findings
- Trends in incidents, vulnerabilities, and control failures

Significant or urgent findings **MUST** be reported promptly rather than waiting for the normal reporting cycle.

III.17.13 Continuous Improvement

Review and testing results **SHOULD** be used to improve procedures, training, technical controls, documentation, and resource allocation.

Repeated failures **MUST** be investigated to determine whether the underlying process, ownership, training, or control design requires improvement.

Part IV

C Programming Standard

This project uses a restricted subset of ISO C11 intended to improve memory safety, type safety, portability, analyzability, and maintainability.

The C11 standard is organized into the following areas:

- general principles;
- language subset;
- formatting;
- naming;
- Variables;
- module boundaries;
- public and private visibility;
- type safety;
- initialization;
- control flow;
- functions;
- memory safety;
- arrays and strings;
- pointers;
- integer safety;
- error handling;
- preprocessor usage;
- external libraries;
- concurrency;
- documentation and verification.

IV.1 General Principles

Clarity First: Code should be as readable as prose, spoken aloud.

Simplicity is Beauty: Short, understandable code reduces bugs; remove dead code and refactor duplicates into functions.

Consistent Style: Align with existing project style; use format-conversion tools if needed.

IV.2 C11 Language Subset

IV.2.1 Permitted Language

Source code shall conform to ISO C11. Compiler extensions shall not be used unless they are isolated behind a documented platform abstraction.

Rules prohibit unrestricted control flow and recursion. Instead it requires statically bounded loops, restricted runtime allocation, requires return-value checks, limit the preprocessor use, restrict the use of pointers, and require warning-free compilation and static analysis.

IV.2.2 Prohibited or Restricted Features

The following features require documented justification:

- unions;
- bit-fields;
- flexible array members;
- volatile objects;
- atomics;
- function pointers;
- implementation-defined behavior;
- compiler extensions;
- direct hardware access;
- dynamic memory allocation.

The following features are prohibited:

- `goto`;
- `setjmp`;
- `longjmp`;
- direct recursion;
- indirect recursion;
- variable-length arrays;
- implicit function declarations;
- implicit integer-to-pointer conversions;
- implicit pointer-to-integer conversions;
- function-like macros where an inline function is practical;
- compiler-specific types in portable modules;
- unbounded loops in deterministic modules;
- unrestricted global mutable state.

IV.3 Formatting

IV.3.1 Indentation

Tabs shall be used for indentation. Spaces shall not be used to represent indentation.

One tab shall represent one logical indentation level. The display width of a tab shall be four spaces in the project editor configuration.

IV.3.2 Alignment

Spaces may be used for alignment within a line, but alignment shall not create a requirement for additional whitespace on later lines.

IV.3.3 Braces

Braces shall always be used for compound statements, including statements containing only one instruction.

Opening braces shall appear on the same line as the associated statement.

```
if (condition) {  
    process_item();  
} else {  
    handle_error();  
}
```

IV.3.4 Whitespace

There shall be spaces:

- around binary operators;
- after commas;
- between a type and a variable name where appropriate.

After every keyword (if, while, etc) of the C language, a space must be added. e.g.

```
if (i == 1)  
while (i == 0)
```

keywords include:

- if
- switch
- case
- for
- do
- while

but not:

- sizeof

- `typeof`
- `alignof`
- `attribute`

There shall be no trailing whitespace.

IV.3.5 Line Length

Lines should not exceed 100 characters. A longer line is permitted only when breaking it would reduce readability.

IV.3.6 Automated Formatting

All C files shall be processed using the project-approved formatter configuration. Manual formatting preferences shall not override the project formatter.

Package indent under Debian and Ubuntu Linux distributions is recommended for formatting C code. On windows it can be found here: <https://gnuwin32.sourceforge.net/packages/indent.htm>

IV.4 Naming

IV.4.1 General Naming Requirements

Names shall describe the purpose, behavior, or ownership of the object they identify. Abbreviations shall be avoided unless they are widely understood within the project.

Names shall:

- use lowercase `snake_case` for functions and variables;
- use uppercase `UPPER_SNAKE_CASE` for macros;
- use descriptive names for types;
- distinguish counts, sizes, indexes, capacities, and offsets;
- avoid names that differ only by capitalization;
- avoid names that shadow variables in an enclosing scope;
- avoid single-letter names except for short loop indexes;
- avoid misleading names.

IV.4.2 Functions

Functions shall use verb-based names that describe their operation.

```
buffer_init();
buffer_write();
buffer_clear();
packet_is_valid();
```

Boolean-returning functions should use names such as:

```
is_valid();
has_error();
can_write();
```

IV.4.3 Variables

Variables shall describe their content and, where useful, their unit.

```
size_t packet_length;
uint32_t timeout_ms;
uint8_t retry_count;
bool connection_is_open;
```

Names such as `data`, `value`, `temp`, and `result` should be avoided unless their meaning is clear from the local context.

IV.4.4 Types

Project-defined types shall use a consistent project convention.

```
typedef struct buffer buffer_t;
typedef enum device_state device_state_t;
```

Structure tags and typedef names shall not unnecessarily duplicate one another.

IV.4.5 Constants and Macros

Constants should preferably be represented using typed constants, enumerations, or `static const` objects instead of macros.

```
static const size_t max_packet_length = 1024U;
```

Macros shall use uppercase names with a project-specific prefix.

```
#define PROJECT_MAX_PACKET_LENGTH 1024U
```

IV.4.6 Private Names

Private file-scope functions and variables shall use `static`. A project prefix may be used for private names when required to avoid collisions with external symbols.

IV.5 Variables

IV.5.1 General Variable Requirements

Group local variables together by type.

Do not declare variables after first executable statement.

Each variable has a single purpose; avoid globals.

Prevent name clashes, respect byte order in communication structs, and never use uninitialized variables.

IV.6 Module Boundaries

IV.6.1 Module Structure

Each module shall consist of:

- one public header file, when an external interface is required;

- one source file;
- private declarations contained in the source file;
- unit tests for externally visible behavior.

A module shall have one primary responsibility.

IV.6.2 Header Independence

Every public header shall compile independently when included into an otherwise empty translation unit.

```
#include "buffer.h"

int main(void)
{
    return 0;
}
```

IV.6.3 Include Ownership

A source file shall include the header that declares its public interface before other project headers.

```
#include "buffer.h"

#include <stddef.h>
#include <stdint.h>

#include "memory.h"
```

IV.6.4 Circular Dependencies

Circular dependencies between modules are prohibited.

Modules shall depend on abstractions or narrow interfaces rather than including unrelated internal headers.

IV.7 Visibility

IV.7.1 Public Declarations

A public declaration is any declaration exposed through a module's interface header.

Public declarations shall be limited to:

- functions intended for use by other modules;
- opaque object types;
- public enumerations;
- public constants;
- public error codes;
- public configuration structures when required by the interface.

IV.7.2 Private Declarations

Private functions, variables, constants, and types shall be defined in the corresponding source file.

Private file-scope declarations shall use the `static` specifier.

```
static uint32_t calculate_checksum(const uint8_t *data,
                                   size_t length);

static uint32_t checksum_seed = 0U;
```

IV.7.3 Global Variables

Global mutable variables are prohibited.

File-scope variables shall be private unless there is a documented architectural reason for making them public.

Public variables shall not be used for ordinary module communication. Functions shall be used instead.

IV.7.4 Opaque Types

Public headers should expose opaque structures rather than structure definitions.

```
/* buffer.h */

#ifndef PROJECT_BUFFER_H
#define PROJECT_BUFFER_H

#include <stddef.h>
#include <stdint.h>

typedef struct buffer buffer_t;

buffer_t *buffer_create(uint8_t *storage, size_t capacity);
int buffer_write(buffer_t *buffer,
                 const uint8_t *data,
                 size_t length);
size_t buffer_size(const buffer_t *buffer);

#endif
```

The structure definition remains private:

```
/* buffer.c */

struct buffer {
    uint8_t *storage;
    size_t capacity;
    size_t length;
};
```

IV.8 Type Safety

IV.8.1 Fixed-Width Integer Types

Fixed-width integer types shall be used when the width or signedness is important.

```
#include <stdint.h>
```

```
uint32_t packet_length;
int32_t temperature;
uint8_t status;
```

The types `int8_t`, `uint8_t`, and similar types shall be used instead of assuming the size of `char`, `short`, or `int`.

IV.8.2 Boolean Values

Boolean values shall use `bool` from `<stdbool.h>`.

```
#include <stdbool.h>

bool packet_is_valid;
```

Integer values shall not be used as booleans unless the conversion is explicit and documented.

IV.8.3 Enumerations

Enumerations shall be used for finite sets of named states.

```
typedef enum {
    MODE_IDLE = 0,
    MODE_ACTIVE,
    MODE_ERROR
} mode_t;
```

IV.8.4 Explicit Conversions

Conversions that may change signedness, width, precision, or interpretation shall be explicit.

```
uint32_t value = 0U;
uint16_t reduced_value = (uint16_t)value;
```

The conversion shall be safe. A cast shall not be used merely to silence a compiler warning.

IV.8.5 Const Correctness

The `const` qualifier shall be used whenever an object is not modified through a pointer.

```
void process_packet(const uint8_t *data, size_t length);
```

IV.8.6 Additional Rules

- Do not compare signed and unsigned values without an explicit conversion or documented reason.
- Do not use plain `char` for binary data.
- Do not use `float` or `double` for exact quantities.
- Do not rely on the size of `int`.
- Do not use casts to convert unrelated pointer types.
- Do not use type-punning through incompatible pointer types.
- Do not use an enumeration outside its defined semantic domain.

IV.9 Initialization

IV.9.1 General Requirement

Every object shall be initialized before it is read.

Initialization shall occur as close as practical to the declaration.

```
uint32_t retry_count = 0U;  
bool packet_is_valid = false;
```

Uninitialized local variables are prohibited.

IV.9.2 Default Initialization

Objects shall be initialized to a valid and documented default state.

```
struct device device = {  
    .state = DEVICE_STATE_OFF,  
    .timeout_ms = 1000U,  
    .error_code = ERROR_NONE  
};
```

Designated initializers shall be used for structures when they improve clarity or protect against changes in member ordering.

IV.9.3 Structures

Structure members shall be initialized explicitly when their zero value is not the required default.

The following form is preferred for complete initialization:

```
struct configuration configuration = {  
    .enabled = true,  
    .retry_limit = 3U,  
    .timeout_ms = 500U  
};
```

IV.9.4 Arrays

Arrays shall be initialized explicitly when partial initialization could hide an error.

```
uint8_t header[HEADER_LENGTH] = {0U};
```

IV.9.5 Pointers

Pointers shall be initialized to a valid object or to NULL.

```
uint8_t *buffer = NULL;
```

A pointer shall not be dereferenced unless its validity has been established.

IV.9.6 Static Storage

Static and file-scope objects shall have an explicit initializer when the initial state is important to the module contract.

IV.9.7 Initialization Functions

Initialization functions shall:

- be called before any other operation on the object;
- be safe to call only according to their documented contract;
- establish all required invariants;
- report failure explicitly;
- leave the object in a documented state when initialization fails.

```
int device_init(device_t *device);
```

IV.9.8 Partial Initialization

An object shall not be exposed to other modules until initialization is complete.

If initialization requires multiple steps, cleanup shall be defined for each partially initialized state.

IV.10 Control Flow

IV.10.1 Control Flow

The following are prohibited:

- goto;
- setjmp;
- longjmp;
- recursion;
- deeply nested conditionals;
- hidden control flow in macros.

IV.10.2 Loops

Loops shall have a clear termination condition.

Loops in deterministic or safety-critical code shall have a statically reviewable upper bound.

```
for (size_t index = 0U; index < MAX_ITEMS; ++index) {  
    process_item(items[index]);  
}
```

A loop controlled by external input shall still have a maximum iteration limit.

IV.11 Functions

IV.11.1 Function Requirements

Functions shall:

- have one primary responsibility;
- have a clearly defined contract;
- validate input parameters;
- return an explicit status for recoverable failure;
- avoid hidden side effects;
- avoid modifying caller data unless documented;
- remain short enough for complete review.
- Limit nesting depth to four levels.

Functions should normally have no more than 10 local variables. If more are required, the function should be refactored into smaller functions.

Every function that may be accessed from outside its module **MUST** include a function prototype (declaration).

Function declarations and definitions that accept no parameters **MUST** explicitly use (void), never empty parentheses ().

Function implementations **MUST** place the return type and any storage-class or qualifier keywords on a separate line from the function name.

A function **SHOULD** have at most 2 return points: one early return at the top of the function for parameter/argument validation, and one return at the end of the function. Avoid return statements in the middle of the function body; use a return-value variable to accumulate the result instead.

IV.11.2 Parameter Validation

Public functions shall validate all pointer parameters, lengths, ranges, and state assumptions that are not guaranteed by the type system.

IV.11.3 Return Values

The caller shall check every non-void return value.

If a return value is intentionally ignored, the reason shall be explicit.

```
(void)log_message("startup complete");
```

IV.12 Memory Safety

IV.12.1 General Requirement

Code shall not produce:

- out-of-bounds accesses;
- use-after-free;
- double-free;
- invalid frees;
- null-pointer dereferences;

- uninitialized reads;
- memory leaks;
- access through a dangling pointer;
- writes through a read-only object;
- integer-overflow-derived allocation sizes.

For maximum safety general rules include:

- no heap allocation in core logic;
- no heap allocation unless needed;
- caller-provided buffers where possible;
- explicit buffer lengths;
- no hidden ownership transfer;
- no ownership implied only by naming;
- cleanup paths tested.

IV.12.2 Allocation Policy

Static allocation and caller-provided storage are preferred.

Dynamic allocation shall be avoided in ordinary modules and is prohibited after initialization in deterministic or safety-critical modules.

Every allocation shall have:

- one owner;
- one documented release path;
- a checked failure path;
- a defined maximum size;
- a test for boundary conditions.

IV.12.3 Allocation Arithmetic

Allocation-size arithmetic shall be checked before allocation.

```
if (count > SIZE_MAX / sizeof(*items)) {
    return ERROR_SIZE_OVERFLOW;
}

items = malloc(count * sizeof(*items));
if (items == NULL) {
    return ERROR_OUT_OF_MEMORY;
}
```

IV.12.4 Ownership

Functions shall document whether pointer parameters are:

- borrowed and not retained;
- owned by the caller;
- transferred to the callee;
- returned with ownership transferred to the caller.

IV.13 Arrays and Strings

IV.13.1 Array Bounds

Every array access shall be demonstrably within bounds.

A pointer to an array shall be accompanied by its length unless the length is guaranteed by the interface contract.

```
int process_bytes(const uint8_t *data, size_t length);
```

IV.13.2 String Handling

The following functions are prohibited:

- `gets`;
- `strcpy`;
- `strcat`;
- `sprintf`;
- `scanf` without a field-width limit.

String operations shall specify destination capacity and shall preserve null termination.

IV.13.3 Binary Data

Binary buffers shall use `uint8_t` and an explicit length. They shall not be treated as null-terminated strings.

IV.14 Pointers

IV.15 Integer Safety

IV.16 Error Handling

IV.17 Preprocessor

IV.18 External Libraries

IV.18.1 Library Policy

The project shall depend only on:

- the ISO C11 standard library;
- operating-system interfaces required by the target;
- project-owned libraries;
- third-party libraries approved in the dependency register.

A third-party library shall not be added solely for convenience when the required functionality can be implemented safely using C11 or existing project code.

IV.18.2 Approval Requirements

Each external library shall have:

- a documented purpose;
- a version pinned in the build system;
- a license record;
- a maintenance status;
- a security review;
- a documented public API surface;
- a removal or replacement plan where practical.

IV.18.3 Wrapper Requirement

External libraries shall be accessed through a project-owned wrapper module.

Application modules shall not include third-party headers directly unless the dependency is explicitly approved as part of the public architecture.

```
/* project_json.h */

#ifndef PROJECT_JSON_H
#define PROJECT_JSON_H

int project_json_parse(const char *text);

#endif
```

IV.19 Concurrency

IV.19.1 Applicability

Concurrency includes operating-system threads, interrupt handlers, callbacks, signal handlers, asynchronous tasks, and hardware event handlers.

Concurrency shall not be introduced unless it is required by the system design.

IV.19.2 Shared State

Shared mutable state shall be minimized.

Every shared object shall have a documented synchronization strategy.

The following are prohibited:

- undocumented shared mutable state;
- data races;
- unsynchronized access to shared objects;
- relying on timing for correctness;
- using `volatile` as a replacement for synchronization.

IV.19.3 Ownership

Each shared object shall have one of the following documented policies:

- protected by a mutex;
- accessed only by one thread;
- accessed atomically;
- immutable after initialization;
- exchanged through a documented message-passing interface.

IV.19.4 Mutexes

Mutex acquisition and release shall be visibly paired.

```
mutex_lock(&state_mutex);  
  
update_shared_state();  
  
mutex_unlock(&state_mutex);
```

A mutex shall not be held while calling an external function unless the locking contract explicitly permits it.

IV.19.5 Lock Ordering

When multiple locks are required, the project shall define a global lock ordering.

Locks shall always be acquired in that order to prevent deadlock.

IV.19.6 Atomics

C11 atomic objects shall be used only when their memory-ordering behavior is understood and documented.

The default sequentially consistent ordering shall be preferred unless a different ordering is justified.

IV.19.7 Interrupts and Signal Handlers

Signal handlers and interrupt handlers shall perform minimal work.

They shall not call functions that are not safe in their execution context.

Communication with the main application shall use an approved mechanism, such as an atomic flag, queue, or event object.

IV.19.8 Thread Cancellation

Thread cancellation shall not be used unless cleanup behavior is fully defined.

Resources shall not be leaked when a thread exits or is cancelled.

IV.19.9 Testing

Concurrent code shall be tested under:

- repeated execution;
- increased scheduling variability;
- thread and lock analysis;
- race detection where supported;
- sanitizer-enabled builds where supported.

IV.20 Documentation

IV.20.1 Documentation Requirements

Documentation shall explain intent, contracts, assumptions, ownership, and limitations. It shall not merely repeat the implementation.

Documentation shall be updated whenever behavior or interfaces change.

IV.20.2 Public Interfaces

Every public function shall document:

- its purpose;
- each parameter;
- the return value;
- possible error conditions;
- ownership and lifetime rules;
- thread-safety requirements;
- whether pointers may be NULL.

```
/**
 * @brief Writes bytes to a buffer.
 *
 * @param buffer Buffer that receives the data.
 * @param data Input data. The memory is borrowed and is not retained.
 * @param length Number of bytes to write.
 *
 * @return 0 on success.
 * @return -1 if an argument is invalid.
 * @return -2 if insufficient capacity is available.
 *
 * @threadsafe No. The caller shall provide synchronization.
 */
int buffer_write(buffer_t *buffer,
                 const uint8_t *data,
                 size_t length);
```

IV.20.3 Module Documentation

Each module shall document:

- its responsibility;
- its public interface;
- its dependencies;
- its ownership model;
- its initialization requirements;
- its thread-safety model;
- its error-reporting strategy.

IV.20.4 Comments

Comments shall explain why the code exists, not simply describe what the code visibly does.

Poor comment:

```
// Increment index  
index++;
```

Useful comment:

```
// The hardware requires a delay after reset before the status register becomes valid.  
delay_ms(HARDWARE_RESET_DELAY_MS);
```

For multi-line comments use space+asterisk for every line

IV.20.5 TODO Comments

TODO comments shall include an issue identifier or owner.

```
// TODO(PROJ-142): Replace polling with event notification.
```

Unowned TODO comments shall not be committed to production code.

IV.20.6 Generated Documentation

Public interfaces should use a consistent documentation format, such as Doxygen. Generated documentation shall be treated as a build artifact and shall not replace source-level documentation.

IV.21 Tooling

IV.21.1 Compiler

The compiler shall be configured for C11:

```
-std=c11
```

The following warning categories should be enabled for GCC or Clang:

```
-Wall  
-Wextra  
-Wpedantic
```

```
-Wconversion
-Wsign-conversion
-Wshadow
-Wcast-qual
-Wcast-align
-Wstrict-prototypes
-Wmissing-prototypes
-Wformat=2
-Wundef
-Werror
```

The exact warning set may vary by compiler, but all warnings shall be resolved or formally justified.

IV.21.2 Analysis

The project shall use:

- compiler warnings;
- a static analyzer;
- AddressSanitizer during testing;
- UndefinedBehaviorSanitizer during testing;
- a formatter;
- unit tests;
- boundary and negative tests.

IV.21.3 Required Build Checks

A merge shall be rejected if:

- formatting fails;
- compilation produces warnings;
- static analysis produces unreviewed findings;
- sanitizers detect an error;
- unit tests fail;
- coverage or safety requirements are not met.

IV.22 Exceptions

IV.22.1 Purpose

Exceptions provide a controlled method for deviating from this standard. They shall not be used to avoid normal engineering review.

IV.22.2 When an Exception Is Required

An exception is required when code:

- uses a prohibited language feature;

- introduces an unapproved external dependency;
- exposes a normally private symbol;
- uses dynamic allocation in a restricted module;
- suppresses a compiler or static-analysis warning;
- violates a mandatory formatting or naming rule;
- requires implementation-defined or compiler-specific behavior;
- cannot satisfy a memory, type, or concurrency rule.

IV.22.3 Exception Record

Each exception shall document:

- the rule identifier;
- the affected file, module, or function;
- the reason for the deviation;
- the risks introduced;
- the mitigation or compensating control;
- the approving reviewer;
- the date of approval;
- the planned review or expiration date.

Field	Value
Rule identifier	C-MEM-004
Affected module	<code>network_buffer.c</code>
Deviation	Dynamic allocation is used after initialization.
Reason	Incoming packet size is not known during startup.
Mitigation	Maximum allocation is bounded and failure is handled.
Approver	Technical lead
Review date	2026-10-03
Status	Approved

IV.22.4 Warning Suppression

Warning suppression shall be localized to the smallest possible scope.

A suppression shall include a comment explaining:

- which warning is suppressed;
- why it is safe;
- why the code cannot be rewritten to avoid it.

Suppressing warnings globally is prohibited.

IV.22.5 Review

Exceptions shall be reviewed when the affected module changes and at each major release.
Expired or no-longer-needed exceptions shall be removed.

Part V

Python Programming Standard

This part defines the coding and design requirements for Python source code.

V.1 Python Formatting

V.1.1 Formatting Rules

Python code shall follow PEP 8 and the project formatter configuration.

- Four spaces shall be used for indentation.
- Tabs shall not be used.
- Lines should not exceed 88 characters.
- Black shall be used for automatic formatting.
- Ruff shall be used for linting.

```
def calculate_checksum(data: bytes) -> int:
    """Return the checksum for a byte sequence."""
    return sum(data) % 256
```

V.1.2 Code Organization

Keep functions and methods short and focused

Follow the Single Responsibility Principle

Use classes to encapsulate related functionality

Separate concerns into different modules

V.2 Python Documentaion

V.2.1 General Documentaion Rules

Document all public modules, classes, methods, and functions

Include type hints for function parameters and return values

Document parameters, return values, and exceptions raised

V.3 Python Naming

V.4 Python Imports

V.4.1 Import Rules

Group importsd in the following order:

1. Standard library imports.

2. Related third party imports.
3. Local application/library specific imports.

Use absolute imports when possible

Avoid wildcard imports (e.g. `from module import *`).

Use import aliases for long module names

V.5 Type Hints

V.5.1 Type Hints

Public functions and methods shall include type hints for parameters and return values.

```
def load_configuration(path: str) -> dict[str, str]:  
    """Load configuration values from a file."""  
    ...
```

Static type checking should be performed using mypy or the project-approved equivalent.

V.6 Functions and Classes

V.7 Error Handling

V.7.1 General Error Handling

Use specific exception types instead of generic ones

Handle exceptions at the appropriate level

Use context managers ('with' statements) for resource management

Avoid catching exceptions without proper handling

V.8 Testing

V.8.1 General Testing

Write unit tests for all code

Use meaningful test names

Test both normal and edge cases

Mock external dependencies in tests

V.9 Python Review Checklist

Part VI

Tooling and Verification

Part VII

Development Process

A Example Documents:

VII.1.0.1 A clean JSA

	Business Unit:		Work Permit No:	Date:
	Site/Area:			
	TASK NAME:			
	TASK DESCRIPTION:			

Prepared by:	Approved by:		Sign:						
Reviewed by:	Review Date:	Review No.:	Sign:						
MINIMUM PPE		ADDITIONAL PPE REQUIRED							
PPE:	Goggles	Full Face Shield	Gloves	Fall Arrest Systems	Hearing Protection	Barricades	High Visibility Vest	Lighting	Other
	Double Eye Protection	Welding Face Shield	Harness	Dust Mask/ respirator	Welding Screen	Erect Warning Signs	Fire Extinguisher	Personal Locks or Tag	

Permit Required		Have You?		Does the job involve prescribed High Risk activities?	
General		Visited the Worksite ?		Confined space work	
Excavation / Dig		Checked for relevant procedures ?		Cranage and Lifting	
Confined Space Entry		Reviewed applicable MSDS sheets?		Scaffolding	
Hot Works		Communicated with work interfaces?		Trenching and excavation	
Working with Height		Had new members review the SWMS?		Use of plant and equipment	
Vicinity Authority		Checked inspection & tagging is		Working at Height	
Isolation		Legislation that is applicable:		Work in potentially contaminated or flammable atmosphere	
		State/ Territory OSH ACT	Other:	Non Routine work activities, or novel construction methods	
		State/ Territory OSH REG's		If YES: See supervisor to obtain relevant SWMS or to assist in creating new SWMS	

List Equipment and or Plant Required	Crew sign on							
	NAME		SIGNATURE		NAME		SIGNATURE	
Competence, Qualification/ Training required to complete work safely:								
Isolated, Try Start Performed. Verified	Supv		Supv		Witness		Witness	

Risk Rating = Likelihood x Severity

S e v e r i t y	Catastrophic	5	5	10	15	20	25
	Significant	4	4	8	12	16	20
	Moderate	3	3	6	9	12	15
	Low	2	2	4	6	8	10
	Negligible	1	1	2	3	4	5
			1	2	3	4	5
			Improbable	Remote	Occasional	Probable	Frequent
			Likelihood				

Catastrophic		STOP
Unacceptable		URGENT ACTION
Undesirable		ACTION
Acceptable		MONITOR
Desirable		NO ACTION



Potential Hazards

This list may not identify all potential hazards present. Visit the job site to ensure all hazards are identified. If a potential hazard has no impact on the job, mark the box with "NP" for not present. If a potential hazard impacts on the job/task, tick the box and implement appropriate control measures in the SWMS.

☐

BARRIERS & SIGNAGE

Are barriers required to be in place?
Open holes, excavation. Persons working above etc

☐

CLIMATIC

Are temperature and weather conditions a consideration?

☐

CONFINED SPACE

Are you required to work within a confined space?
Permits, rescue plans

☐

ELECTRICAL

Does the work involve electrical isolation or live equipment?
Overhead lines, Switchboards, power tools etc.

☐

ERGONOMIC

Is manual lifting involved?
Pulling, pushing, and or lifting?
Is your work area non restricted?

☐

EXCAVATIONS

Are excavations required?
Barricades, access egress.

☐

FLORA / FAUNA

Are there any environmental considerations? Local land issues. Chemical impact.
Could the task impact or be impacted by local fauna?

☐

FLYING OBJECT

Can objects be ejected under pressure?

☐

GRAVITY

Is there a potential for falling objects?
Secured tools, kick boards installed where applicable

☐

HAZ SUBSTANCE

Is the use of chemicals, acids, solvents or hazardous materials required? Containment, spill kits, MSDS available

☐

HEALTH

Are there any health implications?
Heat, cold, fumes, chemicals etc.

☐

HOT - COLD SURFACES

Are there any hot or cold surfaces that could cause burns, injury or damage equipment?

☐

ISOLATION

Are isolations required?
Consider Locking/ Tagging requirements

☐

LIGHTING

Is adequate lighting available to perform the task safely?

☐

MECHANICAL

Has all plant and equipment been checked prior to use.
Is there any pinch/ crush hazards, sharp edges?

☐

NOISE

Will excess noise pose a problem to hearing and/or communications?

☐

PRESSURE

Is there stored pressure?
Is stored pressure restrained? (whip checks)

☐

RADIATION

Is there the potential for burn or exposure to radiant sources?
X-Ray?

☐

VEHICULAR

Can vehicle enter the task area?
Will vehicles used during the task present hazard to task or others?

☐

VIBRATION

Can vibration impact on of persons/ equipment/ ground stability/ structures?

☐

WASTE- HOUSEKEEPING

Is the work area free of Slip/ Trip/ Fire hazards?

☐

WORK SURFACE

Are there slip trip hazards?
Loose/ wet/ or uneven ground. Obstacles.

☐

WORKING AT HEIGHT

Is working at heights require?
EWP's, Harnesses etc available

☐

OTHER

Emergency Response: The SWMS should consider egress routes, location of nearest safety shower/eye wash, BA, alarm, shutdown switch, fire equipment, etc

TICK WHICH CODE OF PRACTICE(S) IS APPLICABLE TO TASK.

Hazardous Substances		Electrical Practices for construction work		Excavation		Manual Handling		Moving Plant on Construction Sites		Noise Management & protection of hearing	
Work in hot and cold environments		Work near over power lines		Prevention of falls in workplace		Abrasive Blasting		Other:			

		Site:			Work Permit No:		Date:	
		TASK:						
Step #	Job Step	Hazard.	Risk Rank	Control		Residual Risk	Responsible Person	

SAFE WORK METHOD METHOD STATEMENT (JSA) AMMENDMENTS

Step #	Change Made	Date	Name	Signature

Take 5 Safety Inspection

Date: Location/Task Name Prepared By

INSTRUCTIONS:

The Take 5 Safety Checklist is a quick and effective tool to assess potential hazards before starting a task. Carefully review each item and mark the corresponding checkbox to indicate that you have considered and addressed the safety aspects of the task. Use the "Notes" section to provide additional details or record any safety observations.

1. STOP AND THINK

- Have you taken a moment to stop and think about the task? ☐ Yes ☐ No ☐ NA
- Have you considered any potential hazards or risks associated with the task? ☐ Yes ☐ No ☐ NA
- Are you mentally prepared to proceed with the task safely? ☐ Yes ☐ No ☐ NA

2. ASSESS THE ENVIRONMENT

- Have you checked the work area for any hazards or obstructions? ☐ Yes ☐ No ☐ NA
- Is the area well-lit, and are there no trip hazards? ☐ Yes ☐ No ☐ NA
- Have you considered weather conditions that may affect the task? ☐ Yes ☐ No ☐ NA

3. PERSONAL PROTECTIVE EQUIPMENT (PPE)

- Have you identified the required PPE for this task? ☐ Yes ☐ No ☐ NA
- Are you wearing the necessary PPE to protect against identified hazards? ☐ Yes ☐ No ☐ NA
- Is your PPE in good condition and properly fitted? ☐ Yes ☐ No ☐ NA

4. TOOLS AND EQUIPMENT

- Are you using the appropriate tools and equipment for the task? ☐ Yes ☐ No ☐ NA
- Have you inspected the tools and equipment for any defects? ☐ Yes ☐ No ☐ NA
- Are the tools and equipment in good working condition? ☐ Yes ☐ No ☐ NA

5. SAFETY PROCEDURES

Have you reviewed the safety procedures and guidelines for this task?

☐

Yes

☐

No

☐

NA

Do you understand the steps and precautions involved?

☐

Yes

☐

No

☐

NA

Are you aware of the emergency procedures in case of an incident?

☐

Yes

☐

No

☐

NA

NOTES

[Insert any additional notes or safety observations made during the Take 5 Safety Checklist]

Prepared By

:

Signature

:

Date

:

Inspection template by:



Digitize your Audits & Inspections through SafetyMint

Get started with a free trial at www.safetymint.com

B C Review Checklist

- ☐ C-REV-001 All compiler warnings are resolved.
- ☐ C-REV-002 All return values are handled.
- ☐ C-REV-003 Pointer ownership is documented.
- ☐ C-REV-004 Memory allocation failures are handled.
- ☐ C-REV-005 Loop bounds are reviewable.
- ☐ C-REV-006 Static-analysis warnings are resolved.
- ☐ C-REV-007 Unit tests cover boundary conditions.
- ☐ C-REV-008 The code follows the project formatter.

C Python Review Checklist

- ☐ PY-REV-001 The code is formatted with Black.
- ☐ PY-REV-002 Ruff reports no unresolved violations.
- ☐ PY-REV-003 Public functions have type hints.
- ☐ PY-REV-004 Public interfaces have docstrings.
- ☐ PY-REV-005 Exceptions are handled explicitly.
- ☐ PY-REV-006 External resources use context managers.
- ☐ PY-REV-007 Tests cover invalid and boundary inputs.

D Release Checklist

References

- [gnu] gnuwin. *Indent for Windows*. URL: <https://gnuwin32.sourceforge.net/packages/indent.htm>.
- [Gui01] Alyssa Coghlan Guido van Rossum. *PEP 8 – Style Guide for Python Code*. July 2001. URL: <https://peps.python.org/pep-0008/>.
- [Lin25] Liangxu Linux. *Essential C Coding Standards for Clear, Safe, and Maintainable Code*. Jan. 2025. URL: <https://www.besthub.dev/articles/essential-c-coding-standards-for-clear-safe-and-maintainable-code-a57dfba7dd0e>.
- [MaJ18] MaJerle. *C Code Style*. 2018. URL: <https://github.com/MaJerle/c-code-style> (visited on 10/03/2026).
- [pro] projectrules.ai. *Python Coding Standards*. URL: https://www.projectrules.ai/rules/python_standards.
- [Sci] SciLab. *Code Conventions for the C Programming Language*. URL: [https://scilab.gitlab.io/legacy_wiki/Code\(20\)Conventions\(20\)for\(20\)the\(20\)C\(20\)Programming\(20\)Language.html](https://scilab.gitlab.io/legacy_wiki/Code(20)Conventions(20)for(20)the(20)C(20)Programming(20)Language.html).